WSB MERITO UNIVERSITY WROCLAW

Faculty of Finance and Management

Field: Information Technology

Fred Junior NTWALI

(Student`s index number: 91686)

Designing a Secure Identity and Access Management Framework Using Microsoft Entra and On-Prem Active Directory

Engineering project work

Supervisor:

mgr Przemysław Żarnecki

Wroclaw 2026

Abstract

Enterprise IT environments are undergoing rapid transformation as organizations adopt cloud-first strategies, remote work models, and modern endpoint management. In this context, traditional on-premises Active Directory (AD)–only identity architectures are increasingly insufficient, particularly in hybrid infrastructures where cloud and legacy systems must coexist. The transition to Windows 11 and the growing adoption of Microsoft Intune for device management further accelerated this shift, as identity and access control move from a network-centric model toward identity as the primary security perimeter.

This engineering thesis presents the design and implementation of a secure and scalable hybrid Identity and Access Management (IAM) framework that integrates Microsoft Entra ID (formerly Azure Active Directory) with on-premises Active Directory. The proposed framework aims to provide unified identity management, consistent access control, and enhanced security across both cloud and on-premises resources while adhering to Zero Trust principles. The solution leverages Microsoft Entra Connect for hybrid identity synchronization, PowerShell-based automation for identity lifecycle management, and cloud-native security controls including Conditional Access, Multi-Factor Authentication (MFA), Role-Based Access Control (RBAC), and Privileged Identity Management (PIM).

The framework is implemented and evaluated within a simulated enterprise environment reflecting contemporary deployment scenarios, including Intune-managed Windows 11 endpoints, hybrid authentication flows, and Joiner–Mover–Leaver identity lifecycle processes. Testing focuses on functional correctness, security enforcement, and resilience against common identity-related threat vectors such as credential misuse and stale account exploitation.

The results demonstrate that a hybrid IAM architecture built around Microsoft Entra ID significantly improves access governance, reduces reliance on perimeter-based controls, and enhances protection against identity-based attacks while maintaining interoperability with existing Active Directory infrastructures. This work provides a practical reference architecture and implementation guidance for organizations seeking to modernize their identity platforms and transition securely toward cloud-based, policy-driven IAM models.

List of Abbreviations

1. IAM Iden ty and Access Management
2. AD Active Directory

3. Entra ID Microsoft Entra ID (formerly Azure Active Directory / Azure AD)
4. AAD Azure Active Directory (legacy name for Entra ID)
5. RBAC Role-Based Access Control
6. ABAC Attribute-Based Access Control
7. PBAC Policy-Based Access Control
8. MFA Mul -Factor Authentication
9. SSO Single Sign-On
10. CA Conditional Access
11. PIM Privileged Iden ty Management
12. JML Joiner–Mover–Leaver (Identity Lifecycle Management)
13. SSPR Self-Service Password Reset
14. GPO Group Policy Object
15. OU Organizational Unit
16. UPN User Principal Name
17. SID Security Identifier
18. AD DS Active Directory Domain Services
19. DNS Domain Name System
20. DC Domain Controller
21. DHCP Dynamic Host Configuration on Protocol
22. LDAP Lightweight Directory Access Protocol
23. Kerberos Authentication Protocol
24. Intune Microso Intune (Endpoint Management System)
25. MDM Mobile Device Management
26. MEM Microsoft Endpoint Manager
27. ADFS Active Directory Federation on Services
28. PTA Pass-Through Authentication
29. PHS Password Hash Synchronization on
30. AADC Azure AD Connect
31. SCP Service Connection Point
32. GUI Graphical User Interface
33. CLI Command-Line Interface
34. PowerShell Windows PowerShell (Scripting Language)
35. API Application Programming Interface
36. Graph API Microsoft Graph API
37. JSON JavaScript Object Nota on
38. CSV Comma-Separated Values
39. VPN Virtual Private Network
40. SIEM Security Information and Event Management
41. SOC Security Operations Center
42. UAM User Access Management
43. CIS Center for Internet Security
44. NIST National Institute of Standards and Technology
45. ISO International Organization on for Standardization
46. GDPR General Data Protection Regulation
47. PKI Public Key Infrastructure

48. TLS Transport Layer Security
49. SAML Security Assertion Markup Language
50. OAuth2 Open Authorization 2.0
51. JWT JSON Web Token
52. SCCM System Center Configuration on Manager
53. VM Virtual Machine
54. VHD Virtual Hard Disk
55. RDP Remote Desktop Protocol
56. BYOD Bring Your Own Device
57. TOTP Time-Based One-Time Password
58. CSV Comma-Separated Values
59. DNS Domain Name System
60. MSAL Microsoft Authentication on Library
61. OIDC OpenID Connect
62. GUI Graphical User Interface
63. TPM Trusted Platform Module

Table of Contents

Abstract 1
List of Abbreviations 2
Chapter 1: Introduction 9
1.1 Background 10
1.2 Motivation and Case Study 11
Chapter 2: Aim, Objectives, and Scope 12
2.1 Research Aim 12
2.2 Research Objectives 12
2.3 Research Questions 13
2.4 Scope and Limitations 14
2.5 Methodology and Project Plan 15
Chapter 3: Overview of Identity and Access Management (IAM) 16
3.1 Definition and Importance of Identity and Access Management (IAM) 16
3.2 Core Components of IAM Systems 17
3.2.1 Authentication and Authorization 17
3.2.2 Identity Provisioning and Lifecycle Management 18
3.2.3 Access Control Models (RBAC, ABAC, and PBAC) 19
3.3 IAM in Modern Enterprise Environments 20
3.3.1 Drivers of Change: Cloud, Mobility and Remote Work 21
3.3.2 Architectural Patterns: Hybrid Identity and Federated Access 21
3.3.3 Core Capabilities Required in Modern IAM 22
3.3.4 Security Model: Zero Trust and Identity as the New Perimeter 23
3.3.5 Operational and Organizational Considerations 23
3.3.6 Challenges and Risks 24
3.3.7 Standards, Compliance and Best Practices 24
3.3.8 Practical Implications for the Proposed Framework 25
3.4 Microsoft IAM Ecosystem Overview 25
3.4.1 Microsoft Active Directory (On-Premises) 25
3.4.2 Microsoft Entra ID (Cloud Directory) 26
3.4.3 Entra Connect and Federation Services 26
3.5 Evolution of IAM: From Traditional to Zero Trust 26
3.6 Business Drivers and Benefits of a Hybrid IAM Approach 27
Chapter 4: Designing a Secure IAM Framework 28
4.1 Framework Design Principles 29
4.2 Architectural Overview of the Proposed Framework 30
4.3 Integration Between Entra and Active Directory 32
4.4 Identity Synchronization and Federation Mechanism 33
4.5 Implementation of Security Controls 34
4.5.1 Multi-Factor Authentication (MFA) 34
4.5.2 Conditional Access Policies 35

4.5.3 Role-Based Access Control (RBAC) 36
4.5.4 Least Privilege and Just-in-Time Access 36
4.6 Monitoring and Logging Mechanisms 37
4.7 Data Protection and Compliance Considerations 38
Chapter 5: Testing and Evaluation of the IAM Framework 39
5.1 Testing Methodologies 39
5.1.1 Functional Testing..... 39
5.1.2 Integration Testing 40
5.1.3 Performance Testing 40
5.1.4 Security Testing 41
5.2 Testing Environment Setup 41
5.3 Evaluation Metrics 42
5.4 Results and Observations..... 42
5.5 Security Assessment Findings 43
5.6 Compliance Validation (NIST, ISO/IEC 27001) 44
Chapter 6: Implementation and Case Study..... 45
6.1 Overview of Implementation Environment 45
6.2 On-Prem Active Directory Configuration 45
6.3 Microsoft Entra ID Configuration 46
6.4 Hybrid Identity Synchronization Using Entra Connect..... 47
6.5 Applying Conditional Access and MFA 47
6.6 Role Management and Access Control Scenarios 48
6.7 System Testing and Validation 49
6.8 Results Analysis and Discussion 49
6.9 Challenges and Mitigation Strategies 50
Chapter 7: Conclusion and Recommendations 52
7.1 Summary of Findings..... 52
7.2 Contributions of the Study..... 53
7.2 Recommendations for Organizations..... 54
7.3 Suggestions for Future Research 55
References..... 56
Appendices 59
Appendix A: Conditional Access Policy Configuration Templates 59
Appendix B: PowerShell Automation Script Concepts 60
Appendix C: Testing Checklist 61
Appendix D: Glossary of Key Terms 62
Statement of Originality 63

Chapter 1: Introduction

Identity and access management is a major aspect of my work life and studies. Identity and access management (IAM) is a security discipline that allows the right people to access the right resources at the right time for the right reasons, according to Microsoft. IAM is a critical cybersecurity component for any organization to maintain the confidentiality, integrity and availability of information systems in the age of digital transformation.

From on-premises enterprise apps to cloud collaboration tools to email, nearly every business depends on digital systems to carry out their day-to-day operations, which means that these systems need to authenticate and govern users to prevent unauthorized access, data breaches, and insider abuse. For decades, traditional identity management systems like on-premises AD have been delivering centralized authentication and authorization, but with the transition to cloud computing and hybrid infrastructures, these systems cannot solve the new problems that arise.

With the rise of remote work, cloud computing, and mobile access, the demand for flexible, cloud-based identity solutions that can handle complex authentication scenarios has grown. Microsoft Entra ID (previously called Azure Active Directory) is a powerful cloud identity platform that enables intelligent, scalable, and secure identity management, but enterprises must navigate architectural, security, and policy challenges to integrate Entra ID with existing onpremises Active Directory environments to maintain seamless identity experiences.

A hybrid IAM framework that securely, scalable, and manageably connects on-premises AD with Microsoft Entra ID is increasingly needed to bridge this gap, and ensures ongoing protection against modern identity-based threats such as phishing, privilege escalation, and credential theft.

The design and implementation of a secure Identity and Access Management (IAM) framework that unifies Microsoft Entra and on-premises Active Directory environments is the main focus of this thesis. In order to ensure that users can safely access both on-premises and cloud resources with uniform policies and improved security controls, the research attempts to provide a workable architecture that fortifies authentication, authorization, and governance.

1.1 Background

In recent years, the exponential increase in digital technologies has combined with growing demands for identity management systems that are easy to use, yet scalable, to change the security landscape of today. Identity and access management (IAM) is a core component of modern organizational security, acting as an overarching framework that governs who has what under what circumstances to establish digital trust in a more interconnected world, to allow businesses to protect sensitive data, meet compliance requirements and keep business running.

Enterprise identity management, which provides centralized authentication and authorization for user accounts, group policies, and permissions in business networks, is typically built on traditional IAM systems that rely on on-premises AD infrastructures, which are stable and proven but inherently lack flexibility, remote access, and integration with modern cloud services as enterprises embrace cloud computing, mobile workforces, and Software-as-a-Service (SaaS) applications.

To address these issues, the industry has been shifting toward solutions based on the Cloud, such as Microsoft Entra ID, formerly Azure Active Directory that is transitioning from a traditional identity system to an identity platform that distributes identities globally in multi-factor authentication with conditional access policies and SSO cloud and hybrid environments improve administrative efficiency, user experience while strengthening security.

However, the transition to hybrid environments combining cloud and legacy on-premises systems has brought complexity and risks. Although Active Directory is used for internal authentication and Entra ID is used for cloud applications such as Dynamics, Microsoft 365 and third-party services, interoperability, secure synchronization and consistency of enforcement between the two identity ecosystems are still a challenge for many companies.

This may result in greater privileges, credential theft, and unauthorized access, which can lead to identity theft, inconsistent access policies, and weak integration links that can be a major threat to the organization. Such problems can only be solved by a hybrid IAM framework that securely connects Microsoft Enterprise ID and Active Directory on-premises, with unified identity management, centralized access control, and real-time monitoring under the guidance of zero trust principles, stricter compliance with industry standards, granular authentication, and more authentication.

But designing such a system requires careful planning, a deep understanding of Microsoft identity architecture, and strict security policy validation. IAM frameworks should undergo policy, performance, and security validation to validate their reliability and resilience against modern cyber threats, much as conformance testing ensures interoperability in telecommunications. This research aims to design and evaluate a secure hybrid IAM framework that integrates Microsoft Entra ID with On-Prem Active Directory in hybrid enterprise environments for the purposes of both operational efficiency and better protection.

1.2 Motivation and Case Study

This thesis is motivated by the urgency to enhance organizational cybersecurity as digital infrastructures evolve and enterprises move from traditional on-prem environments to cloudbased services and hybrid IT environments, where identity management, secure access, and compliance with global security standards become increasingly challenging.

Although traditional AD is robust and widely used, it has been designed for on-premises, centralized environments, and is not flexible enough to meet the dynamic needs of modern organizations operating in a hybrid cloud-on-premise environment. With credential theft, privilege escalation and unauthorized access being one of the most common reasons for data breaches in today's threat environment, organizations are being pressed to implement more comprehensive, adaptive and interconnected identity security architectures. Microsoft Entra ID (formerly Azure Active Directory) is the next generation cloud identity platform, bringing authentication and access control capabilities to the cloud, including zero trust access control.

This thesis is therefore driven by the necessity to design a secure, hybrid Identity and Access Management (IAM) framework that seamlessly integrates Microsoft Entra ID and On-Prem Active Directory by filling critical identity governance, authentication security, and policy consistency gaps in hybrid infrastructures using Microsoft hybrid identity technologies, including Entra Connect, Conditional Access, and Zero Trust principles.

The case study of this research will be applied in a simulated enterprise environment with hybrid infrastructure conditions that include on-prem Active Directory and Microsoft Entra ID configured for synchronization and policy enforcement. The testing and evaluation will focus on the authentication flow, access control mechanisms, and security policies under different scenarios to validate the effectiveness of the proposed IAM framework to enhance protection and operational efficiency.

Ultimately, this research aims to contribute to the growing field of hybrid identity management by offering a practical, tested, and secure model that organizations can adopt to reduce security risks while maintaining scalability and productivity in their modern IT ecosystems.

Chapter 2: Aim, Objectives, and Scope

2.1 Research Aim

The objective of this research is to design and implement a secure hybrid IAM framework by integrating Microsoft Entra ID (Azure AD) with on-premises Active Directory to provide a unified, scalable, and resilient identity management solution for modern enterprises, addressing challenges such as uncontrolled access, credential exposure, and the growing complexity of managing identities in hybrid cloud environments.

This research will also assess how Microsoft Entra can help to strengthen access management, authentication mechanisms and role-based access control (RBAC) to improve security, user experience and compliance with organizational and regulatory standards, while ensuring interoperability with existing on-premises infrastructures. In addition, the research aims to provide a reference architecture and best practice implementation model for the secure management of user identities, devices and access rights in distributed environments, and to contribute to the wider cybersecurity domain by providing practical insights for institutions in the transition from traditional on-premises IAM systems to cloud-based, policy-driven IAM systems with reduced security risks and enhanced operational efficiency.

2.2 Research Objectives

In order to achieve the general objective of designing a secure hybrid identity and access management framework that integrates Microsoft Entra and on-premises Active Directory, the following specific objectives are set:

1. Analyze existing problems and security gaps related to traditional Acgive Directory on-premises environments, including issues of identity, fragmentation, privilege escalation, and access control vulnerabilities.

2. Evaluate the capabilities and security features of Microsoft Entity ID (Azure Active Directory) and its role in enhancing authentication, authorization, and identity management in cloud and hybrid infrastructures.

3. Design a hybrid IAM architecture that securely integrates Microsoft Entra ID with On-premises Active Directory, allowing for centralized identity management, synchronous authentication, and consistent access policies across the two.
4. Implement and test the proposed IAM framework and validate its effectiveness in enhancing identity security, access management and interoperability of the system in a simulated or organizational environment.

5. Develop a set of best practice and policy recommendations for organizations that want to move from legacy on-premises IAM systems to a secure hybrid identity model that is compliant with industry model that is compliant with industry standards and regulatory requirements.

6. Assess the overall impact of the proposed IAM framework on the organization's cybersecurity position, focusing on metrics such as access control effectiveness, threat mitigation and administrative management.

2.3 Research Questions

The following research questions address the objectives and methodology of this thesis and provide a structured framework for analyzing the technical, operational, and security challenges associated with hybrid identity environments. They support the design, implementation, and evaluation of a secure Identity and Access Management (IAM) framework integrating Microsoft Entra ID with on-premises Active Directory in modern hybrid enterprise infrastructures.

1. How can Microsoft Entra ID and on-premises Active Directory be securely integrated to establish a robust hybrid identity foundation?

This question focuses on the core technical integration of hybrid identity systems, examining authentication models (e.g., Password Hash Synchronization, Pass-Through Authentication, and federation with AD FS), secure configuration of Microsoft Entra Connect, and network architecture considerations required to achieve a trusted, encrypted, and highly available synchronization mechanism with a minimized attack surface.

2. What are the established and emerging best practices for managing the complete identity lifecycle within a hybrid environment?

This question examines identity lifecycle governance across cloud and on-premises environments, including role-based access control, privileged access management, and access certification. The

objective is to synthesize governance principles aligned with Zero Trust and industry standards to inform the design of a consistent and secure hybrid IAM framework.

3. To what extent can automation, through tools such as PowerShell and the Microsoft Graph API, enhance the efficiency, accuracy, and security of key IAM processes?

This question evaluates the impact of automation on identity provisioning, deprovisioning, group management, and compliance monitoring. It assesses whether automated IAM workflows measurably reduce administrative overhead, human error, and policy inconsistency compared to manual identity management practices.

4. How does modern Unified Endpoint Management (UEM) use Microsoft Intune reshape traditional IAM enforcement models?

This question investigates the role of device identity and compliance in access control decisions. It explores how Intune-integrated Conditional Access policies enable context-aware enforcement based on device posture, ownership (corporate or BYOD), and security state, particularly in the context of Windows 11–based environments.

Research Hypotheses:

To enable systematic evaluation of the proposed hybrid IAM framework, the following research hypotheses are formulated. These hypotheses define the expected technical and operational outcomes of integrating Microsoft Entra ID with on-premises Active Directory and guide the validation activities presented in the implementation and testing chapters.

H1: The secure integration of Microsoft Entra ID with on-premises Active Directory using hybrid identity synchronization mechanisms enables a resilient and reliable hybrid identity foundation while reducing dependence on perimeter-based authentication models.

H2**:** The application of cloud-native access governance mechanisms—such as Role-Based Access Control, Privileged Identity Management, and Conditional Access—improves access consistency and limits excessive privileges compared to traditional on-premises IAM approaches.

H3: Automating identity lifecycle processes using PowerShell and Microsoft Graph API integration improves the efficiency, accuracy, and security of Joiner–Mover–Leaver workflows by minimizing manual intervention and reducing the risk of stale or orphaned accounts.

H4: Integrating Microsoft Intune–based Unified Endpoint Management with Microsoft Entra ID strengthens identity enforcement by enabling context-aware access decisions based on device compliance, ownership, and security posture.

H5: The proposed hybrid IAM framework enhances an organization's overall security posture by improving protection against identity-based threats while maintaining interoperability with legacy on-premises systems.

These hypotheses are evaluated through practical implementation, testing, and analysis of authentication behavior, access control enforcement, and security policy effectiveness within the simulated enterprise environment presented in subsequent chapters.

2.4 Scope and Limitations

This research focuses on the design, implementation, and evaluation of a secure hybrid Identity and Access Management (IAM) framework integrating Microsoft Entra ID (formerly Azure Active Directory) with on-premises Active Directory. The scope includes architectural design, identity synchronization mechanisms, authentication and authorization controls, identity lifecycle management, and access governance in hybrid cloud environments. Particular emphasis is placed on Conditional Access policies, Multi-Factor Authentication (MFA), Role-Based Access Control (RBAC), and integration with modern endpoint management using Microsoft Intune.

While the study provides a comprehensive and practical examination of hybrid IAM design, several limitations must be acknowledged, as they influence the generalizability and empirical scope of the results.

Technical Complexity:
Hybrid IAM systems inherently involve complex interactions between cloud and on-premises components, authentication protocols, synchronization mechanisms, and security policies. Due to this complexity, the research focuses on representative and commonly adopted configurations rather than exhaustive coverage of all possible advanced or vendor-specific scenarios. Consequently, certain edge cases and highly customized enterprise deployments fall outside the scope of this study.

Resource and Environment Constraints:
The implementation and testing of the proposed framework were conducted within a simulated enterprise environment. Limitations related to access to enterprise-grade infrastructure—such as full Microsoft 365 E5 licensing, advanced Microsoft Entra ID Premium features, and large-scale production identity datasets—restricted the ability to perform large-volume scalability and stress testing. As a result, performance and resilience findings should be interpreted as indicative rather than definitive for large multinational deployments.

Impact on Result Validity:
Because testing was performed in a controlled laboratory environment, real-world operational variables—such as unpredictable user behavior, heterogeneous legacy applications, and

organization-specific governance models—were not fully represented. While this does not invalidate the architectural and security conclusions, it limits direct quantitative comparison with production enterprise environments. The results primarily validate correctness, security enforcement, and architectural feasibility rather than long-term operational performance at scale.

Dynamic Technology Landscape:
Identity and access management technologies evolve rapidly, particularly within cloud platforms such as Microsoft Entra. Changes to features, licensing models, or security recommendations may affect the applicability of certain configurations over time. This study reflects the state of available technologies and best practices at the time of implementation and should be adapted accordingly as platforms evolve.

Application Scope:
The proposed framework is primarily applicable to organizations operating within Microsoft-centric environments that combine on-premises Active Directory with Microsoft Entra ID. Organizations using alternative cloud ecosystems, non-Windows infrastructures, or different IAM platforms may require architectural modifications not covered in this research.

Despite these limitations, the study provides a valid and practically applicable hybrid IAM reference framework. The findings remain relevant for evaluating architectural design decisions, security control effectiveness, and migration strategies toward modern, identity-centric access management in hybrid enterprise environments.

2.5 Methodology and Project Plan

The design, integration, and security aspects of a hybrid Identity and Access Management (IAM) framework utilizing Microsoft Entra and On-Prem Active Directory (AD) are methodically examined in this thesis's several chapters. To completely comprehend hybrid identity systems and their security implications, the methodology combines theoretical research, system design, and practical implementation.

Chapter 3 describes the background and literature review, which provides an overview of Identity and Access Management, the evolution of IAM technologies, and the security challenges in hybrid environments, the components and functions of both On-Prem Active Directory and Microsoft Entra, how they are integrated together to form a unified identity infrastructure, existing IAM frameworks, industry standards (such as Zero Trust and NIST guidelines), and related studies to identify the research gaps addressed by this thesis.
Chapter 4, you will see the design and architecture of the proposed IAM framework, including the integration of Microsoft Entra with On-Prem Active Directory via Entra Connect, Entra Connect Sync, and federation services. You will learn about security design principles such as least privilege, conditional access, and multifactor authentication (MFA) and how they can be used to build a robust and scalable IAM solution in an enterprise environment.

Chapter 5 explains the technical process and configuration of the hybrid IAM system, such as how to synchronize the directory, set up the authentication flow, define identity protection policies, and govern access, as well as the tools, technologies, and environments involved and the criteria for assessing the security, reliability, and performance of the system.

Chapter 6 evaluates and analyzes the implemented framework, comparing its performance and security against predetermined performance and security benchmarks, such as authentication speed, policy enforcement accuracy, and threat resilience, and identifying limitations, interoperability challenges, and recommendations for improving system resilience and compliance within hybrid IAM environments.
Chapter 7 summarizes the conclusions and findings, highlights contributions and recommendations, and discusses the practical implications for organizations implementing similar IAM structures, as well as possible future research topics such as automation, artificial intelligence-based identity analytics and cross-platform federations.

The methodology used in this study ensures a balanced approach between theory and real-world application by combining qualitative analysis, framework design, and experimental validation. This thesis attempts to close the gap between theoretical IAM models and useful, secure hybrid identity frameworks by combining academic research with real-world configurations.

Chapter 3: Overview of Identity and Access Management (IAM)

This chapter provides a foundational overview of Identity and Access Management (IAM), its evolution, core components, and role in modern enterprise environments. It examines traditional and cloud-based identity systems, introduces hybrid identity architectures, and establishes the security principles that underpin the proposed framework. This chapter combines industry standards, vendor documentation, and recent academic research to establish both a practical and theoretical foundation for the proposed hybrid Identity and Access Management framework.

3.1 Definition and Importance of Identity and Access Management (IAM)

According to Gartner, Identity and Access Management (IAM) is “a system of policies, technologies, and processes that controls the appropriate level of access for technology resources at any given time for the right people with the correct identities authenticated by those who have authority to approve them.” IAM defines how users and systems are identified, authenticated, authorized, and governed throughout their lifecycle.

IAM systems typically include authentication mechanisms, authorization models, directory services, identity provisioning, Single Sign-On (SSO), Multi-Factor Authentication (MFA), and identity governance capabilities. These components collectively control access to applications, data, and infrastructure resources across both on-premises and cloud environments.

In modern enterprises operating hybrid and multi-cloud infrastructures, IAM has become a primary security control plane. Studies consistently show that compromised credentials remain one of the leading causes of security breaches, emphasizing the need for robust identity protection mechanisms. IAM also plays a critical role in regulatory compliance, supporting requirements from standards such as ISO/IEC 27001, GDPR, and NIST SP 800-63 by enabling auditable access controls and automated lifecycle management.

Recent academic research confirms that identity compromise is the dominant initial attack vector in hybrid and cloud-based enterprise environments, reinforcing the shift toward identity-centric security models rather than traditional network perimeters (Zhang et al., 2023; Almutairi et al., 2024)

3.2 Core Components of IAM Systems

The identity and access management architecture has multiple components, and each of them has a specific function in the overall identity and access management architecture that ensures secure and effective management of digital identities and access rights within and across hybrid infrastructures (Active Directory (AD) on-premises and Microsoft Entra on-cloud). In the following sections, we will take a closer look at the main components.

3.2.1 Authentication and Authorization

Authentication verifies the identity of a user or system, while authorization determines what resources that identity is permitted to access. In hybrid environments integrating Microsoft Entra ID and on-premises Active Directory, authentication mechanisms typically include passwords, certificates, biometrics, and increasingly MFA.

Federated authentication protocols such as SAML, OAuth 2.0, and OpenID Connect enable centralized identity providers to issue cryptographically secure tokens, allowing users to access multiple applications without re-authentication. Authorization mechanisms enforce least privilege access through role assignments, group memberships, and policy evaluation, including Conditional Access policies that dynamically evaluate contextual factors such as device compliance, location, and risk level.

Together, authentication and authorization enforce the principle of least privilege and form the foundation of Zero Trust security models.

3.2.2 Identity Provisioning and Lifecycle Management

Identity provisioning and lifecycle management refers to the creation, maintenance, and deactivation of user identities as they relate to the relationship with an organization. This helps ensure that user accounts are managed from the time they join the organization to the time they leave. In a hybrid IAM architecture (for example, where Microsoft Entra ID is used with Active Directory), provisioning can be automated via directory synchronization services such as Entra Connect (formerly Azure AD Connect) to keep any changes made to on-prem AD (adding, modifying, or disabling user accounts) in sync with the cloud directory.

This process is typically broken down into three core, continuous phases:

1. Provisioning – The Onboarding Phase

    Provisioning involves creating a new digital identity for the user and the granting of the initial access to the user to get them productive from day one, and this must be done with the appropriate balance between productivity and security principles. Key Activities: Account Creation: Automatically creating user accounts in core systems (e.g., Active Directory, HR systems, email) upon a trigger from the HR system (a "joiner" event). Role and Group Assignment: Assigning the user to predefined roles, security groups, or distribution lists based on their job title, department, and location.

2. Maintenance – The Ongoing Management Phase

    The most dynamic and often the most complex phase is maintenance, which refers to continually updating access as a user's situation within the organization changes to ensure that access continues to match current responsibilities Key Activities: Attribute Updates: Syncing changes in user information (e.g., name change, phone number) across all integrated systems. Departmental Transfers: An employee that transfers from the Marketing department to the Sales department should have access to marketing tools removed and access to sales tools added. Role Changes and Promotions: A promotion from Analyst to Manager should initiate a workflow to grant the new, appropriate set of access rights and revoke those no.

3. Deprovisioning – The Offboarding Phase

    Deprovisioning is the action of revoking all access privileges for a user as soon as they leave an organization or transition to a role that necessitates a different access profile (this is arguably the most critical phase for security). Key Activities: Timely Initiation: Deprovisioning should be automatically initiated based on a "leaver" event in the HR system. Comprehensive Access Revocation: Disabling or deleting the user account across all systems, not just email and network login, but also in SaaS applications, cloud platforms, shared drives, and database systems. Account Archiving: In some cases, accounts are disabled and archived for.

More advanced IAM implementations include workflow automation and self-service for users to reset their passwords, request access, or update their own personal details, all without requiring

administrative intervention, which is supported by Microsoft Entra through Self-Service Password Reset (SSPR) and Access Packages to simplify identity governance and reduce IT operational overhead. Responsibly managing the identity lifecycle ensures compliance with regulations such as GDPR, ISO 27001, and NIST 800-63, as well as consistent access governance across cloud and on-premises systems.

Academic research demonstrates that automated identity lifecycle management significantly reduces configuration errors and the persistence of orphaned accounts, which are frequently exploited during post-compromise lateral movement (Kumar & Tripathi, 2023; Santos et al., 2024).

3.2.3 Access Control Models (RBAC, ABAC, and PBAC)

Access control models specify the rules and mechanisms for granting, enforcing, and monitoring access rights in an IAM system, and the selection of a model can have a significant impact on the scalability, security, and manageability of access across enterprise systems. The three main access control models (RBAC, ABAC, and PBAC) offer different approaches for defining how access is granted.

Role-Based Access Control (RBAC)

With RBAC, permissions are assigned to specific roles in the organization (e.g., users in the "IT Administrator" role may have full system privileges, whereas "Finance Staff" may have limited access to accounting data), which makes the management of permissions easier and is widely adopted in Active Directory via Security Groups and in Microsoft Entra via Role Assignments. RBAC also encourages operational efficiency and compliance because access privileges are aligned with organizational structure and job responsibilities.

Attribute-Based Access Control (ABAC)

ABAC provides flexibility through attribute-based access control, which allows access to be granted based on attributes such as user department, device type, time of access, or location, rather than predefined roles. In hybrid environments, Microsoft Entra Conditional Access is an example of ABAC, which uses contextual signals (such as device compliance or risk level) to determine access, resulting in dynamic access decisions and a form of adaptive security that aligns with the Zero Trust model.

Policy-Based Access Control (PBAC)

PBAC builds on ABAC by placing access rules into policies that are interpreted dynamically by the system, and which are composed of identity attributes, environmental conditions, and organizational rules. Microsoft Entra includes PBAC through its Entra Permissions Management and Conditional Access Policies, which enable administrators to define detailed risk-based access conditions.
These access control models, when used together, can provide a multilayered and dynamic defense, combining the static, job-based permissions of Role-Based Access Control (RBAC) with

the dynamic, situational policies of Attribute-Based Access Control (ABAC) to strike a balance between security and usability, while also ensuring comprehensive protection in a hybrid environment through the use of modern identity platforms like Microsoft Entra ID (Azure AD).

3.3 IAM in Modern Enterprise Environments

From the perimeter-bound networks of yesteryear to the hybrid ecosystems of today with on-premises infrastructure, private clouds, public clouds, mobile endpoints, and an ever-growing list of SaaS applications, IAM is no longer a back-office nicety but the primary control plane for security, compliance, and user productivity in modern enterprise. In this section, we explore how IAM works in today's enterprises, the architectural patterns that have emerged, the operational challenges, and the capabilities needed to secure identities at scale.

3.3.1 Drivers of Change: Cloud, Mobility and Remote Work

Three interrelated trends drive the modern IAM requirements:

- Cloud adoption and SaaS proliferation. Moving from on-premises IT to cloud services shifts the resources from a single network that is under a single control to multiple platforms like AWS, Salesforce, and Microsoft 365, with each service having its own login system and an almost unlimited number of possible points of entry for an attacker. With this identity sprawl, it is impossible to manage access manually. The answer is a centralized identity system that serves as a single source of truth to deliver Single Sign-On (SSO) for users, automate account creation and deletion (provisioning), and apply consistent security rules such as multi-factor authentication across all. .
- Mobility and remote work. The perimeter of the corporate network has dissolved, and employees access sensitive data from untrusted locations, such as home Wi-Fi and coffee shops, on a combination of company-owned and personal devices, rendering the old model of trusting anyone on the corporate network obsolete. Authentication can no longer be a single password; it must be strong, multiple factors to confirm a user's identity, and adaptive, employing contextual signals like the user's location, device security, and network to dynamically evaluate risk in realtime.

- DevOps and automation. In software development, automated pipelines are used to rapidly build, test, and deploy applications and infrastructure, which means they are not operated by human users but by scripts, applications, and services, which need their own identities, often called machine identities, service principals, or API tokens. Because the scale and speed of automation are so great, thousands of these non-human identities can be created with their own set of permissions, and when unmanaged, they become an enormous security blind spot. Thus, machine identities need to be managed and secured with the same rigor as human users, following principles of least.

3.3.2 Architectural Patterns: Hybrid Identity and Federated Access

Modern enterprises commonly adopt one of two complementary architectural patterns:

- Hybrid Identity: This model recognizes that most organizations exist in a hybrid state, with some on-premises infrastructure and some cloud services, where the primary identity source, usually an on-premises Active Directory, continues to manage accounts for legacy applications and internal network access, while a cloud directory like Microsoft Entra ID is deployed to manage access to modern SaaS applications and support secure remote work. A synchronization tool (like Entra Connect) establishes a link that synchronizes identities to the cloud, creating a consolidated identity, so a user can sign in with their corporate credentials only once and access resources without friction.

- Federated and Token-Based Access: This pattern takes authentication beyond basic password authentication to a more secure and flexible model for modern web and API-driven environments by using standardized protocols such as SAML, OAuth 2.0, and OpenID Connect to separate authentication (proving your identity) from authorization (what resource you are allowed to access) and issuing a cryptographically-signed token from a trusted identity provider (such as Entra ID) to the application rather than a password.

3.3.3 Core Capabilities Required in Modern IAM

To operate securely and effectively, modern IAM systems must provide a set of interlocking capabilities:

- Single Sign-On (SSO): Simplifies access across apps and reduces password reuse risk.

- Adaptive / Risk-Based Authentication: Dynamically adjusts authentication requirements according to contextual signals (user risk, device compliance, location, time).

- Multi-Factor Authentication (MFA) & Password less Options: Strong second factors and Password less flows reduce credential compromise.

- Conditional Access & Policy Engine: Centralized policies that evaluate attributes and signals to allow, block or require additional controls.

- Provisioning and Identity Lifecycle Automation: Automated onboarding/offboarding, entitlement assignment, and delegated approval workflows reduce human error and orphaned accounts.

- Privileged Access Management (PAM) and Just-in-Time (JIT) Elevation: Controls for high risk accounts, session recording, and time-bounded elevated privileges.

- Identity Governance and Access Reviews: Periodic certification, attestation and role recertification to prevent privilege creep.

- Device and Endpoint Posture Management: Ensure only compliant and healthy devices can access sensitive resources.

- Monitoring, Logging and Threat Detection: Centralized logging, anomaly detection, and identity protection analytics to detect lateral movement and compromised accounts.

- API and Machine Identity Management: Managing certificates, keys, and service principals with rotation and least privilege.

3.3.4 Security Model: Zero Trust and Identity as the New Perimeter

The Zero Trust model "never trust, always verify" has become the de facto architecture for modern IAM. Zero Trust place's identity at the center:

- Every access request is evaluated irrespective of network location.

- Decisions are based on user identity, device posture, application sensitivity, and risk signals.

- Least privilege and micro-segmentation reduce blast radius after compromise.

Identity becomes the key "control point" for enforcing Zero Trust: strong authentication, continuous session evaluation, and fine-grained authorization are essential to realize the model.

3.3.5 Operational and Organizational Considerations

Adopting modern IAM architecture requires organizational changes as well as technical controls:

- Governance and Policy Harmonization: Define consistent identity policies across cloud and on Prem systems (naming, role definitions, onboarding/offboarding processes).

- Change Management and User Education: MFA, conditional access, and new authentication flows necessitate user training and clear communication to avoid friction and shadow workarounds.

- Role Design and Least-Privilege Culture: Implement role design processes and enforce entitlement reviews to prevent privilege accumulation.

- Incident Response and Forensics: Identity-centric logging (sign-in logs, audit trails) must be integrated with SIEM and incident playbooks to enable rapid compromise detection and containment.

3.3.6 Challenges and Risks

Modern IAM faces several persistent challenges:

- Legacy Applications: Many legacy apps lack modern auth protocols; they require connectors, agents, or identity proxies for SSO and conditional access.

- Identity Sprawl and Shadow IT: Multiple identities, service accounts, and unmanaged apps increase attack surface.
- Misconfiguration and Over-Provisioning: Incorrect sync rules, overly broad roles, or permissive conditional access policies can create vulnerabilities.
- Scale and Performance: Large enterprises require scalable directory sync, low-latency authentication, and resilient token issuance at global scale.
- Regulatory and Privacy Constraints: Data residency, auditability, and user consent requirements must be reconciled with identity replication and telemetry.
- Supply Chain & Third-Party Risks: B2B/B2C federation introduces trust boundaries and dependency risks.

Each of these risks must be addressed through a combination of architecture, tooling, policy, and continuous validation.

3.3.7 Standards, Compliance and Best Practices

To ensure robust, auditable IAM deployments, enterprises align with established standards and frameworks:

- NIST SP 800-63 (Digital Identity Guidelines): Guidance on identity proofing, authentication assurance levels and federation.
- ISO/IEC 27001 and 27002: Security management and controls that govern access and identity management.
- GDPR and Data Protection Laws: Ensure identity data handling and audit trails comply with privacy requirements.

Best practices include strong authentication, automated provisioning and deprovisioning, periodic access reviews, use of conditional access policies, deployment of PIM for privileged roles, and integration of identity telemetry into security operations.

3.3.8 Practical Implications for the Proposed Framework

For a hybrid IAM framework integrating Microsoft Entra and On-Prem AD, the modern environment implications are:

- Design for central policy decision, distributed enforcement. Use Entra as the policy engine while preserving AD as the authoritative source for certain identities where appropriate.
- Adopt adaptive authentication and MFA widely, while offering password less options to reduce credential risks.

- Automate lifecycle events via HR integrations and enforce deprovisioning to reduce orphan accounts.
- Implement PIM and JIT for administrative roles to limit privileged exposure.
- Integrate telemetry into the SOC (SIEM) for continuous identity threat detection and response.
- Plan for legacy app integration via federation gateways or identity proxies to apply conditional access even where modern protocols are absent.

3.4 Microsoft IAM Ecosystem Overview

The Microsoft Identity and Access Management (IAM) ecosystem is perhaps the most comprehensive and widely used framework in modern enterprise environments, offering a natural integration of on-premises identity infrastructures with cloud-based identity capabilities to support hybrid, security-driven, and scalable identity models. The Microsoft IAM ecosystem is composed of three core pillars: Active Directory (AD), Microsoft Entra ID, and Microsoft Entra Connect with extended federation services, which together comprise a unified identity control plane that enables authentication, authorization, governance, and Zero Trust security enforcement for enterprise workloads.

3.4.1 Microsoft Active Directory (On-Premises)

Microsoft Active Directory (AD) is a long-standing enterprise directory service that has been available for over 20 years. Originally built for on-premises environments, AD offers authentication, authorization, and identity governance for users, computers, service accounts, and applications. It features Kerberos and NTLM Authentication for local resource access, Group Policy Management for security baselines and device configurations, Organizational Units (OUs) for identity governance and administrative delegation, and Domain Services for centralized identity management of on-prem systems. Although AD is still crucial for legacy applications and internal infrastructures, it is limited in modern cloud-first environments because it is dependent on.

3.4.2 Microsoft Entra ID (Cloud Directory)

Microsoft Entra ID is Microsoft's cloud identity platform to give secure access to cloud applications, SaaS services, and hybrid workloads. It offers a number of capabilities that go beyond AD, such as: Cloud native authentication using OAuth 2.0, OIDC, and SAML Conditional Access Policies that assess user risk, device posture, location, and behavior
Multifactor Authentication (MFA) and Password less authentication (FIDO2, Windows Hello) Identity

Protection using machine learning for threat and anomaly detection Entra ID Privileged Identity Management (PIM) for managed and time-bound admin privileges Seamless Single Sign-On (SSO) for tens of thousands of integrated cloud services Entra ID serves as.

3.4.3 Entra Connect and Federation Services

Microsoft Entra Connect is the tool for unifying on-prem identities with cloud identities using a hybrid identity model, which includes the following functions: Directory synchronization between Active Directory and Microsoft Entra ID Password hash synchronization or pass-through authentication for sign in Hybrid identity governance Support for federation services, such as AD FS, to enable: SAML based authentication Token issuance for cloud services Advanced single sign-on scenarios

3.5 Evolution of IAM: From Traditional to Zero Trust

The fundamental change in Identity and Access Management (IAM) has shifted from protecting the perimeter of the network to the validation of identity itself. The traditional model was a castle-and-moat approach that used firewalls and VPNs to establish a trusted "inside" network, and once a user or device was inside the perimeter, they were typically granted wide access. This is what model was characterized by:

- Password-based authentication
- Domain-joined devices
- Static access permissions
- Limited visibility into identity behavior

Yet mobility, cloud services, remote work, and sophisticated cyber threats made perimeter security inadequate; attackers could use stolen credentials, move laterally within networks, or target legacy authentication protocols. This shift gave rise to the Zero Trust model, where identity, not the network, became the new security perimeter. Zero Trust IAM is predicated on the following principles:

- Never trust, always verify.
- Enforce least privilege access.
- Assume breach and continuously validate.
- Evaluate contextual signals during authentication (risk, device, location)
- Continuous monitoring and session evaluation

Recent peer-reviewed research validates Zero Trust architectures as an effective response to identity-based attacks, particularly in hybrid environments where perimeter assumptions no longer apply (Rose et al., 2023; Ferreira & Correia, 2024)

With features like Conditional Access, Identity Protection, MFA, password less authentication, and Just-in-Time privileged elevation, contemporary IAM platforms like Microsoft Entra ID operationalize Zero Trust. The transition from traditional IAM to Zero Trust reflects the enterprise's need for identity-driven, adaptable security controls that can protect cloud-first infrastructures and distributed environments.

3.6 Business Drivers and Benefits of a Hybrid IAM Approach

Organizations are embracing hybrid IAM models - integrating Microsoft Entra ID with Active Directory on-premises - not only as a technical necessity, but also as a strategic initiative. This approach will bring tangible business value by balancing legacy investments with innovation in the cloud, driven by the following key drivers:

1. Facilitated Cloud Transformation
A lift-and-shift migration is rarely practical. Hybrid IAM allows for a phased transition, where legacy applications that rely on Active Directory remain on-premises while new, cloud-native applications integrate directly with Entra ID, thus de-risking the migration journey, avoiding business disruption, and allowing for a gradual modernization on the organization's timeline.

2. Strengthened Security Posture and Zero Trust Adoption
Hybrid model unlocks next-gen, cloud-native security capabilities and adds on to traditional AD, and Microsoft Entra ID brings Conditional Access with risk-based policies to enforce MFA or block access based on user location, device compliance, or sign-in risk, along with Privileged Identity Management (PIM) for just-in-time admin access and centralized monitoring, to create the adaptive, "never trust, always verify" foundation needed for Zero Trust.

3. Operational Efficiency and Cost Optimization
Organizations see considerable operational savings by moving identity services to the cloud, including fewer physical server hardware, fewer software licenses, and manual effort to maintain, as well as the ability to automate the identity lifecycle management (user onboarding, offboarding, and access reviews) and significantly reducing the number of password-related IT helpdesk tickets with Self-Service Password Reset (SSPR).

4. Enhanced User Productivity and Experience
The single identity significantly improves user experience for end-users as they can now access their apps across all work environments including SSO (Single Sign-On) into cloud applications without having to re-enter credentials, on-premises applications with conditional access without needing passwords and password less sign-in using Windows Hello or the Authenticator app to eliminate friction in productivity regardless of where users are.

5. Streamlined Compliance and Governance

A centralized hybrid identity platform makes it easier to comply with regulatory standards like GDPR, HIPAA, and SOC 2 by enabling strong identity governance, such as centralized audit logs for all access events (cloud and on-prem), automated access certification campaigns, and consistent access policy enforcement across the entire digital estate, resulting in more efficient and accurate compliance reporting.

6. Strategic Flexibility and Futureproofing
A hybrid IAM strategy offers strategic optionality: the ability to keep sensitive or specialized workloads on-premises for data sovereignty or performance reasons, while still being able to take advantage of the agility of new cloud services and features as business needs change so the IAM infrastructure is a business enabler and not a constraint.

Empirical studies indicate that hybrid IAM adoption leads to measurable improvements in access governance, operational efficiency, and incident response effectiveness compared to traditional identity models (Li et al., 2024).

Chapter 4: Designing a Secure IAM Framework

In this chapter, the detailed design of the proposed hybrid IAM framework with Microsoft Entra ID combined with on-premises Active Directory is presented that addresses the security, scalability, and operational requirements identified in the previous chapters while adhering to Zero Trust principles and NIST SP 800-63, CIS Benchmarks, and ISO/IEC 27001. The framework is designed specifically to meet modern enterprise scenarios such as remote work, cloud-first strategies, and the move to Windows 11 with Microsoft Intune-based device management.

4.1 Framework Design Principles

The core architectural principles that form the basis of the proposed hybrid IAM framework are designed to inform all design decisions and implementation choices, ensuring that the resulting system is not only functional but also secure, maintainable, and reflective of the current identity management paradigms that view identity as the new security perimeter in modern distributed computing environments, supplanting the network-centric security model that has failed to adapt to the realities of cloud and hybrid infrastructures.

Principle 1: Identity as the Primary Security Perimeter. With the rise of cloud computing and remote work, the traditional network perimeter model, where resources inside the corporate network were assumed to be inherently trustworthy, has become obsolete. The framework proposed positions identity as the control point for all access decisions, and every authentication request, regardless of its origin or the network location of the requesting entity, is validated against the centralized identity infrastructure, a principle that manifests in the architectural requirement that all resource access flows through identity verification mechanisms before authorization is granted.

Principle 2: Zero Trust Architecture Alignment. The framework follows the Zero Trust security model established by NIST Special Publication 800-207, which stipulates that no user, device, or network segment should be trusted by default and that all access attempts must be verified using at least one of the following mechanisms: explicit identity verification for every access attempt, least privilege access enforcement through role-based and attribute-based access controls, micro segmentation of resources to restrict lateral movement, and continuous monitoring and validation of security posture during user sessions.

Principle 3: Principle of Least Privilege. The least privilege principle is applied throughout the framework design; users and service accounts are provided with only the least amount of permissions required to execute their respective functions, with this principle being implemented through multiple complementary mechanisms, including granular role definitions without permission accumulation, time-bounded access to privileged operations through Privileged Identity Management (PIM), just-in-time elevation workflows that need explicit justification and approval for elevated access, and periodic access reviews that identify and correct unnecessary permissions.

Principle 4: Defense in Depth. Defense-in-depth strategy: This architectural design incorporates multiple layers of security controls to ensure that the failure of a single control does not result in a complete security breach, and this is achieved through layered authentication mechanisms (passwords, MFA, password less authentication), multiple authorization checkpoints (Conditional Access policies, application-level permissions, resource-level access controls), network segmentation that restricts communication between the identity infrastructure components, and comprehensive logging and monitoring that enables detection of anomalous activity at each layer.

Principle 5: Resilience and High Availability. The identity infrastructure is considered a mission critical service that almost every organizational operation depends on, so the framework includes resilience and high availability as core design criteria. Active Directory domain controllers are deployed in redundant configurations across multiple physical locations and, because Microsoft Entra ID is a cloud service, it is inherently high-availability, and the synchronization layer between on-premises and cloud directories is designed to tolerate transient failures without data loss or inconsistency.

Principle 6: Automation and Operational Efficiency. Managed identity management processes are prone to error, are slow and lack scalability. The framework automates identity management, access provisioning, compliance monitoring, and security response, and is technically supported by scripting in the form of the Microsoft Graph API and by the integration of PowerShell to enforce policies in a consistent manner and minimize operational burden for identity administrators.

4.2 Architectural Overview of the Proposed Framework

The proposed hybrid IAM architecture is composed of multiple layers that are interconnected to deliver a full suite of identity and access management capabilities. The architecture separates the cloud layer that houses Microsoft Entra ID and related services from the on-premises layer that contains the Active Directory infrastructure, and the Microsoft Entra Connect synchronization service bridges the two layers to keep the two identity stores in sync and allow for the additional security and management capabilities of the cloud platform.

The architecture is organized into five distinct functional layers, each with specific responsibilities and interfaces:

1. Identity Source Layer: The Identity Source Layer contains the authoritative identity stores, such as on-premises Active Directory Domain Services (AD DS), and any integrated HR systems that are the source of truth for employee identity information, and are responsible for the creation, modification, and deletion of identity records based on organizational events such as hiring, role changes, and terminations.
2. Synchronization Layer: Microsoft Entra Connect works on this layer and provides one way or two-way synchronization of identity attributes between Active Directory on the server and Microsoft Entra ID on the desktop. This layer implements password hash synchronization, authentication agents for authentication, and filtering rules to determine which objects are synchronized with the cloud.
3. Cloud Identity Layer: Microsoft Entra ID is a cloud identity platform that provides authentication services for cloud applications, conditional access policy assessment, identity-protection capabilities, and integration with Microsoft 365 and third-party SaaS applications. This layer also hosts the privileged identity management (PIM) that manages administrative access.
4. Policy and Governance Layer: This layer includes conditional access policies, role based access control definitions, compliance policies, and identity management configurations that determine how access decisions are made. The policy layer spans both cloud and on-premises environments, with the Microsoft Entra ID as the primary policy decision-making point for cloud resources.
5. Monitoring and Analytics Layer: This layer provides visibility of identity-related events via Azure Monitor, integration with Microsoft Sentinel, and on-premises logging of security events. The monitoring layer allows for threat detection, compliance reporting and operational analysis.

Figure 4.1: High-Level Hybrid IAM Architecture

```
┌──────────────────────────────────────────────────────────────────────────────────────────────────────────────┐
│                                                                                                              │
│                CLOUD LAYER (Microsoft Azure)                                                                 │
│  ┌──────────────────────┐  ┌──────────────────────┐  ┌──────────────────────┐                              │
│  │ Microsoft            │  │ Conditional          │  │ Identity             │                              │
│  │ Entra ID             │◄─┤ Access               │◄─┤ Protection           │                              │
│  │ (Directory)          │  │ Policies             │  │ (Risk Engine)        │                              │
│  └──────────────────────┘  └──────────────────────┘  └──────────────────────┘                              │
│                                                                                                              │
│  ┌──────────────────────┐  ┌──────────────────────┐  ┌──────────────────────┐                              │
│  │ Privileged           │  │ Microsoft            │  │ Azure                │                              │
│  │ Identity             │  │ Intune               │  │ Monitor              │                              │
│  │ Management           │  │ (MDM/MAM)            │  │ (Logging)            │                              │
│  └──────────────────────┘  └──────────────────────┘  └──────────────────────┘                              │
└──────────────────────────────────────────────────────────────────────────────────────────────────────────────┘

                    ▲
                    │ HTTPS/TLS 1.2+
                    │
          ┌──────────────────────┐
          │ Microsoft Entra      │
          │ Connect Sync         │
```

```
│ (PHS + PTA Agents) │
└──────────┬──────────┘
           │ LDAP/LDAPS
           ▼
┌──────────────────────────────────────────────────────────────────────────────┐
│ ON-PREMISES LAYER (Corporate Network)                                        │
│ ┌──────────────┐ ┌──────────────┐ ┌──────────────┐                          │
│ │ Domain       │ │ DNS          │ │ Group        │                          │
│ │ Controllers  │◄─┤ Services     │ │ Policy       │                          │
│ │ (AD DS)      │ │ (Integrated) │ │ Objects      │                          │
│ └──────────────┘ └──────────────┘ └──────────────┘                          │
│                                  │                                           │
│ ┌──────────────┐ ┌──────────────┐ ┌──────────────┐                          │
│ │ Certificate  │ │ SIEM/Log     │ │ HR System    │                          │
│ │ Authority    │ │ Collector    │ │ (Source of   │                          │
│ │ (PKI)        │ │ (Sentinel)   │ │ Truth)       │                          │
│ └──────────────┘ └──────────────┘ └──────────────┘                          │
└──────────────────────────────────────────────────────────────────────────────┘
```

The architecture diagram shows the mapping between cloud and on-premises components: The Cloud Layer features Microsoft Entra ID as the primary cloud identity provider, with Conditional Access to enforce policies, Identity Protection for risk-based authentication, and Privileged Identity Management for administrative access governance; Microsoft Intune provides device compliance evaluation, and Azure Monitor aggregates security and operational logs. The Synchronization Layer, represented by Microsoft Entra Connect, provides the secure communication channels between the environments. The On-Premises Layer retains the legacy Active Directory infrastructure with domain controllers, DNS services, Group Policy, and integration with enterprise systems like HR platforms and certificates.

4.3 Integration Between Entra and Active Directory

The technical underpinning of the hybrid IAM framework is the integration between Microsoft Entra ID and on-premises Active Directory, which allows organizations to maintain a single identity for each user while taking advantage of the different capabilities of both platforms. The integration strategy should account for security requirements, operational simplicity, and organizational constraints.

Microsoft provides three primary authentication methods for hybrid identity scenarios, each with distinct characteristics:

Password Hash Synchronization (PHS): In this model, Microsoft Entra Connect extracts hashed passwords from on-premises Active Directory and syncs them to Microsoft Entra ID. Synchronization applies another layer of SHA-256 hashing to the password hashes before sending them, and plaintext passwords are never sent across the network. When a user signs in to a cloud application, Microsoft Entra ID validates the supplied credentials against the synchronized password hash without needing to communicate with on-premises infrastructure. PHS offers the greatest availability of authentication and supports the leaked credential detection of Microsoft Entra ID Identity Protection.

Pass-Through Authentication (PTA): With PTA, the passwords are validated in real-time against on-premises Active Directory, and when the user attempts to authenticate, Microsoft Entra ID encrypts

the credentials and sends them to on-premises PTA agents for validation. Passwords are never stored in the cloud, which meets regulatory requirements that prohibit storing credential material in the cloud, and immediate enforcement of on-premises password policies and account states are available, but there is a dependency on always having connectivity between Microsoft Entra ID and on-premises infrastructure.

Federation with AD FS: Federation with Active Directory Federation Services is the most complex, but also the most flexible, authentication architecture, which trusts the on-premises AD FS infrastructure to authenticate users and issue security tokens, and supports custom authentication methods, smart card authentication, and integration with specialized authentication systems. Federation involves dedicated servers, web application proxies, SSL certificates, and careful network configuration.

For the proposed framework, password hash synchronization is chosen as the primary authentication method, complemented by pass-through authentication agents configured as a secondary mechanism for scenarios requiring instant recovery of account status. This hybrid approach maximizes accessibility while preserving safety and operational benefits. Table 4.1:
Comparison of Hybrid Authentication Methods

Criteria	PHS	PTA	Federation (AD FS)
High Availability	Excellent (cloudnative)	Good (requires agents)	Requires HA deployment
Password Storage	Hashes in cloud	On-premises only	On-premises only
Complexity	Low	Medium	High
Leaked Credential Detection	Supported	Not supported	Not supported
Account State Enforcement	Sync cycle delay	Immediate	Immediate
Infrastructure Required	Entra Connect only	Entra Connect + agents	AD FS servers + proxies

4.4 Identity Synchronization and Federation Mechanism

Microsoft Entra Connect is the synchronization engine that keeps the on-premises Active Directory and Microsoft Entra ID in sync. The synchronization occurs on a scheduled basis with a default interval of 30 minutes, but delta synchronizations can be triggered on-demand when immediate propagation is needed. The synchronization architecture is built to manage enterprise scale directory populations, including ensuring data integrity and security.

Synchronization Architecture: The Entra Connect synchronization engine uses a pipeline of connectors and metaverse operations. The Active Directory connector retrieves objects from on premises AD and stages them in a connector space, the synchronization rules engine processes the objects, applies transformations and filtering as configured, objects that pass the filtering criteria are

projected into the metaverse which acts as an aggregation point for identity attributes from multiple sources, and the Azure AD connector exports the synchronized objects to Microsoft Entra ID.

Attribute Flow and Transformation: Synchronization maps attributes from on-premises Active Directory to attributes in Microsoft Entra ID, and the standard attribute mappings handle common attributes such as userPrincipalName, displayName, and mail. Organizations that have specific attribute transformation needs, such as building cloud UPNs from on-premises attributes or filtering out sensitive attributes, can configure custom synchronization rules.

Filtering and Scoping: The framework uses OU-based filtering to determine what objects get synchronized to the cloud, including only OUs that contain user accounts, groups, and contacts that you want to be available in the cloud, while excluding service accounts, system accounts, and other objects that should stay on-premises only, as well as using attribute-based filtering to exclude objects based on certain attribute values.

Group Synchronization: Security groups are synchronized to Microsoft Entra ID to support cloud-based access control, group membership, and Conditional Access policies and application role assignments that reference on-premises group structures (nested group membership is flattened to reflect inherited permissions in the cloud directory), and group writeback is configured to synchronize groups created in Microsoft Entra ID back to on-premises Active Directory for hybrid scenarios.

Password Writeback: The framework enables hybrid users to take advantage of Self-Service Password Reset (SSPR) by configuring password writeback in Microsoft Entra Connect, which enables users to change their passwords through the Microsoft Entra ID portal or SSPR workflow and have those changes written back to on-premises Active Directory. Password writeback uses the Azure Service Bus to deliver password change events securely and reliably.

4.5 Implementation of Security Controls

The security controls implemented in the proposed IAM framework are a comprehensive security-oriented strategy that addresses authentication, authorization, and access management in both cloud and on-premises environments. These controls are designed to work together to create an overlapping layer of protection which minimizes the impact of any single control failure.

4.5.1 Multi-Factor Authentication (MFA)

Multi-factor authentication is a basic security control that provides protection against credential theft and phishing attacks. The Framework requires macro-financial assistance for all authentication of users to cloud resources, with the specific authentication method varying according to the role of the user, the capabilities of the device and security requirements.

The framework supports multiple MFA methods to accommodate different user scenarios and security requirements:

- Microsoft Authenticator App: Provides push notifications for approval and time-based passwords (TOTPs). The Authenticator application supports matching numbers to prevent MFA fatigue attacks and provides geographic context for login attempts.

- FIDO2 Security Keys: Offer password less, phishing-proof authentication for high security scenarios. FIDO2 keys provide the highest level of authentication assurance and are recommended for privileged users and high value targets.
- Windows Hello for Business: Enables biometric and PIN authentication on Windows 11 devices equipped with the appropriate TPM (Time Marking Device) hardware. Windows Hello credentials are tied to the device and are immune to phishing.
- SMS and Voice Call: Serve as a fallback method for users without access to other methods, but their use is discouraged due to known weaknesses in SMS authentication.

MFA registration is part of the onboarding process for new users, and users must register at least two MFA methods at their first sign-in in case their primary method becomes unavailable. It also enforces authentication strength policies that prohibit access to sensitive applications or administrative functions without the use of phishing-resistant methods.

4.5.2 Conditional Access Policies

Conditional Access in Microsoft Entra ID provides the policy engine for implementing Zero Trust access decisions. Conditional Access policies evaluate a comprehensive set of signals to determine whether to grant access, deny access, or require additional verification. The framework implements a structured hierarchy of policies that address different security scenarios. Table 4.2: Conditional Access Policy Matrix

Policy Name	Conditions	Access Controls	Target Scope
CA001- Require MFA	All cloud apps, Any location	Require MFA	All users (excl. break glass)
CA002- Block Legacy	Legacy auth protocols	Block access	All users
CA003- Compliant Device	Sensitive apps, Windows/iOS/Android	Require compliant device	All users
CA004- High Risk Block	High sign-in risk detected	Block access	All users
CA005MediumRiskMFA	Medium sign-in risk	Require MFA + password change	All users
CA006- Admin Access	Azure/M365 admin portals	MFA + compliant + phishing-resistant	Directory roles
CA007- Geo-blocking	Access from blocked countries	Block access	All users

Conditional access policies are to be assessed in order of their specificity, with the more restrictive policies being considered as the preferred ones. The framework includes break-glass accounts, which are excluded from most conditional access policies, to provide emergency access to the tenant in case of a policy error or service disruption affecting macro-financial assistance.

4.5.3 Role-Based Access Control (RBAC)

Role-based access control provides the basic authorization mechanism in the hybrid IAM framework. The implementation of RBAC is based on the principle that roles, rather than individual users, are assigned permissions and that users gain permissions by being assigned roles. This approach makes access management easier and ensures consistency throughout the organization.

The role hierarchy is designed to reflect the organizational structure while accommodating cross functional access requirements. The framework establishes three categories of roles:

1. Business Roles: These roles are related to the functions of the job and are implemented primarily through Active Directory security groups on the premises synchronized with the Microsoft Entra ID. Business roles include access to specific departments (e.g. Finance-Read-only, HR-Full Access) and to cross-functional roles (e.g. Project-Team Member, Executive-View).
2. Administrative Roles: These roles provide privileged access to functions in the area of identity and infrastructure management. Administrative roles are implemented using Microsoft Entra ID directory roles and managed by privileged identity management. Examples are global administrator, user administrator, and security administrator.
3. Application Roles: These roles are defined in specific applications and control access to features and data in specific applications. Application roles are managed using Microsoft Entra ID enterprise application configuration and can be assigned based on group or individual membership.

4.5.4 Least Privilege and Just-in-Time Access

The Framework implements privileged identity management (PIM) to enforce the principle of minimum privilege in administrative access. PIM turns the model of permanent administrative assignments into a one of temporary, time-based privilege increases. Administrators are assigned eligible roles instead of active roles and must explicitly activate their rights if they need to do so.

The PIM configuration implements the following controls:

- Activation Duration: Activation of the administrative role shall be limited to a maximum of 8 hours for standard operations. Extended activations require additional authorization.
- Justification Requirement: All role activations require a business rationale which shall be recorded for audit purposes.
- Approval Workflow: High privilege roles (Global Administrator, Privileged Role Manager) require approval by the designated reviewers before they can be activated
- MFA on Activation: Multi-factor authentication is required when activating roles, which ensures that the person activating roles can demonstrate their identity.
- Access Reviews: Regular access reviews are planned to ensure that the eligible roles remain appropriate and to remove outdated ones.

4.6 Monitoring and Logging Mechanisms

The monitoring and logging infrastructure provides centralized visibility into identity-related events across both cloud and on-premises environments. Comprehensive logging is a critical requirement for security incident detection, compliance auditing, and effective operational troubleshooting. The proposed framework consolidates identity and access–related log sources into a centralized Security Information and Event Management (SIEM) platform to enable correlation, analysis, and long-term retention.

Microsoft Entra ID Sign-in Logs:
All authentication activities processed by Microsoft Entra ID are recorded in sign-in logs. These records include successful and failed authentication attempts, Multi-Factor Authentication (MFA) challenges, Conditional Access policy evaluations, and identity risk detections. In the standard service tier, sign-in logs are retained for 30 days and can be exported to Azure Monitor or a Log Analytics workspace to support extended retention, querying, and forensic analysis.

Microsoft Entra ID Audit Logs:
Administrative operations performed within Microsoft Entra ID are captured in audit logs. These include user and group lifecycle changes, application and service principal modifications, role assignments, and updates to security or access policies. Audit logs provide a traceable record of administrative actions and are essential for investigating security incidents, validating change management processes, and demonstrating regulatory compliance.

Active Directory Security Event Logs:
On-premises domain controllers generate security event logs related to authentication, authorization, and privileged account usage. Key security events—including successful and failed logons, Kerberos ticket requests, and privileged role assignments (event IDs 4624, 4625, 4672, 4768, 4769, and 4776)—are forwarded to the centralized SIEM platform. This enables correlation between on-premises and cloud-based identity activities and supports detection of hybrid attack patterns.

Microsoft Sentinel Integration:
The framework incorporates Microsoft Sentinel as a cloud-native SIEM and Security Orchestration, Automation and Response (SOAR) solution. Sentinel ingests logs from Microsoft Entra ID, Azure resources, and on-premises systems through Log Analytics connectors. Built-in and custom analytic rules are used to identify common identity-based threats, including anomalous sign-in behavior, password spray attacks, suspicious privileged role activations, and geographically improbable access attempts.

Alerting and Detection Configuration:
The monitoring infrastructure is configured to generate alerts for security-relevant conditions, such as repeated authentication failures from a single source, successful sign-ins originating from blocked or restricted locations, activation of privileged roles outside defined business hours, modifications to Conditional Access or synchronization configurations, and detection of compromised or leaked credentials. These alerts support timely incident response and reduce mean time to detection in identity-centric attack scenarios.

4.7 Data Protection and Compliance Considerations

The proposed framework addresses data protection and regulatory compliance requirements relevant to identity management in enterprise environments. Identity-related data including user attributes, authentication information, and access records, may be subject to different legal and regulatory obligations depending on the organization's industry sector and geographic location. The framework is designed to support compliance by incorporating data protection principles into identity synchronization, access governance, and logging mechanisms.

GDPR Compliance:
For organizations subject to the General Data Protection Regulation (GDPR), the framework enforces the principle of data minimization by synchronizing only the identity attributes required for authentication and access control with Microsoft Entra ID. Where applicable, user consent and approval mechanisms can be integrated into identity workflows. Requests related to data subject rights, such as access or rectification, can be supported through Microsoft Entra ID identity management and auditing capabilities.

Data Residency:
Microsoft Entra ID stores identity data in geographically defined datacenters based on the tenant's selected region. For organizations with explicit data residency or sovereignty requirements, the framework requires documentation of identity data flows and storage locations to support regulatory assessments and audits. Identity data maintained within on-premises Active Directory remains under the physical and administrative control of the organization.

Audit Trail and Retention Requirements:
The framework ensures that audit logs and identity-related events are retained in accordance with applicable legal and regulatory requirements. Logging configurations are designed to preserve authentication, authorization, and administrative activity records for required retention periods. To address the default Microsoft Entra ID log retention limit, audit logs are exported to Azure Storage or integrated with a SIEM solution for long-term archival and analysis.

ISO/IEC 27001 Alignment:
The security controls implemented within the framework align with ISO/IEC 27001 requirements, particularly in the areas of access control (A.9), cryptographic controls (A.10), operational security (A.12), and compliance monitoring (A.18). Supporting documentation produced as part of the framework provides evidence of control implementation and can assist organizations pursuing or maintaining ISO/IEC 27001 certification.

Chapter 5: Testing and Evaluation of the IAM Framework

This chapter presents the comprehensive testing and evaluation methodology that has been applied to the proposed IAM Hybrid Framework. The evaluation shall include functional tests to verify that identity management operations are functioning as intended, security tests to verify the effectiveness of security controls, performance tests to assess system responsiveness under stress, and conformity tests to confirm compliance with industry standards. The testing approach shall be guided by established quality assurance principles and shall address the unique characteristics of the identity infrastructure.

5.1 Testing Methodologies

The proposed hybrid IAM framework was evaluated using a structured testing methodology designed to validate its functional correctness, security enforcement, and operational feasibility within a simulated enterprise environment. The evaluation focused on identity integration, authentication behavior, access control enforcement, and resilience against common identity-related security threats.

Testing was conducted across four complementary dimensions: functional testing, integration testing, performance testing, and security testing. Each category directly supports the validation of the research hypotheses formulated in Section 2.3.

5.1.1 Functional Testing

Functional testing verifies that each component of the IAM framework is performing its intended function correctly. The test cases shall be derived from functional requirements determined at the design stage and shall cover the full range of identity lifecycle operations.

User Provisioning Tests: These tests verify that new user accounts are correctly created in the Active Directory on-premises and synchronized with the Microsoft Entra ID within the expected time. Test cases verify that user attributes are well-defined, group memberships are assigned according to role definitions, and that users can authenticate after provisioning to both on-premises and cloud resources.

Authentication Flow Tests: These tests verify that users can verify themselves using the methods they have set up. Test cases include MFA-based password authentication, FIDO2 authentication using Windows Hello keys, seamless single sign-on for domain-joined devices, and authentication from different device types and network locations.

Authorization Tests: These tests verify that authenticated users have access only to resources for which they have been granted permission. Test cases confirm that the RBAC assignments provide adequate access, that the conditional access policy correctly allows or denies access on a conditional basis, and that the application role assignments function properly.

Deprovisioning Tests: These tests verify that user accounts are properly disabled and that access is denied when users quit. Test cases confirm that disabled accounts cannot be authenticated, the synchronization status is updated in the Microsoft Entra ID, and access to resources is immediately denied.

5.1.2 Integration Testing

Integration testing validates the interactions between the components of the IAM framework and ensures that data flows correctly between systems and that workflow is completed successfully from one end to the other.

Directory Synchronization Tests: These tests verify that Microsoft Entra Connect is correctly synchronizing your identity data between Active Directory and Microsoft Entra ID on your Microsoft Office system. Test cases verify initial full synchronization, delta synchronization of changes, password hash synchronization, password writeback functionality, and synchronization of groups.

HR System Integration Tests: If the framework is integrated with HR systems for automated provisioning, these tests verify that the events of joining, moving and leaving trigger the appropriate identity management workflow. Test cases confirm that new hiring records lead to account creation, role changes lead to access changes, and termination records lead to deprovisioning.

SIEM Integration Tests: These tests verify that SIEM is correctly forwarding and ingesting security events from Microsoft Entra ID and Active Directory on-premises. The test cases confirm receipt of log-in events, audit events and security alerts, which may be correlated for the investigation of an incident.

5.1.3 Performance Testing

Performance testing assesses the responsiveness and scalability of the IAM framework under different load conditions. Performance requirements are essential for identity infrastructure, as authentication latency has a direct impact on the productivity of users and the availability of applications.

Authentication Latency Tests: These tests measure the time taken to complete verification operations under normal and peak load conditions. The goal is to have a cloud authentication latency below 500 milliseconds for 95 percent of requests. Test scenarios include standard MFA password authentication, password less authentication and authentication during periods of maximum use.

Synchronization Performance Tests: These tests measure the time it takes for changes to an identity to propagate from the Active Directory on-premises to the Microsoft Entra ID. The delta synchronization target is propagation time of 30 minutes under normal conditions and 2 hours during high volume periods of transformation.

Concurrent User Tests: These tests verify that the framework can handle the expected number of concurrent requests for authentication without crashing. Load testing simulates peak authentication scenarios, such as when many users log on at once at the start of a workday.

Metric	Observed Result	Evaluation
Cloud authentication latency	< 2 seconds	Acceptable
MFA challenge completion	< 5 seconds	Acceptable
Conditional Access evaluation	Near real-time	Acceptable
Directory sync propagation	~30 minutes (default cycle)	Expected
Manual delta sync	Immediate	Expected

5.1.4 Security Testing

The security tests confirm that the security controls implemented within the framework effectively protect against common identity-based attacks. The testing approach shall include both automated vulnerability detection and manual techniques for penetration testing.

Credential Attack Testing: These tests confirm the effectiveness of password-based security against attacks. Test scenarios include password spam attacks using lists of common passwords, brute-force attacks against individual accounts, and credential stuffing using credentials from known data breaches. The expected result is that these attacks are detected and prevented by identity protection and intelligent lockout.

MFA Bypass Testing: These tests attempt to circumvent the controls for multi-factor authentication. Test scenarios include session hijacking attempts, MFA fatigue attacks by repeating push notifications, and attacks against legacy authentication protocols. The expected result is that MFA cannot be circumvented and that legacy authentication is blocked.

Privilege Escalation Testing: These tests verify that users cannot increase their privileges beyond the level that they are authorized to do so. Test scenarios include attempts to assign administrative roles without authorization, use of incorrect policy settings for conditional access, and attempts to access resources outside the authorized scope.

Conditional Access Bypass Testing: These tests attempt to access resources without meeting the requirements for conditional access. Test scenarios include access from blocked locations using a VPN or proxy service, access from devices that are not compliant, and attempts to use legacy protocols to circumvent modern authentication requirements.

Scenario	Expected behavior	Observed Result
Credential misuse attempt	MFA required / access blocked	Blocked
Legacy authentication attempt	Access denied	Blocked
Sign-in from risky location	MFA enforced or blocked	Enforced
Stale user account	Access revoked	Revoked
Privileged role misuse	Just-in-Time approval required	Enforced

5.2 Testing Environment Setup

The test environment reproduces the production structure on a small scale, providing a realistic verification context while maintaining isolation from the production systems. The test environment shall consist of:

- On-Premises Infrastructure: A dedicated Active Directory Forest with two domain controllers running Windows Server 2022, configured as a production environment with the same organizational unit and group policy objects.
- Microsoft Entra ID Tenant: A separate Microsoft Entra ID tenant with P2 license that enables all security features, including identity protection and privileged identity management.
- Synchronization Infrastructure: Microsoft Entra Connect is installed on a dedicated server and configured to use the same synchronization rules as the production deployment.
- Client Devices: Windows 11 devices that are registered in Intune and configured with the compliance policies of the organization, as well as unmanaged devices to test device based conditional access policies.
- Test User Population: A set of test user accounts that represent different roles, departments, and levels of access within an organization.

5.3 Evaluation Metrics

The evaluation shall use quantitative and qualitative metrics to assess the effectiveness of the IAM framework in the areas of safety, operational aspects and user experience. Table 5.1: Evaluation Metrics and Targets

Metric	Target	Measurement Method	Category
Authentication Success Rate	> 99.5%	Sign-in log analysis	Operational
Authentication Latency (P95)	< 500ms	Performance monitoring	Performance
Sync Propagation Time	< 30 min	Timestamp comparison	Operational
MFA Adoption Rate	100%	Authentication reports	Security
Credential Attack Block Rate	100%	Penetration testing	Security
Orphaned Account Count	0	Access review audit	Governance
Privileged Access with PIM	100%	Role assignment audit	Governance

5.4 Results and Observations

The testing phase has produced comprehensive results which confirm the effectiveness of the proposed hybrid framework for IAM. This section presents the main findings of each category of tests.

Functional Testing Results: All functional test cases passed with excellence. User provisioning operations completed within the expected times and accounts were in Microsoft Entra ID within 35 minutes of their creation in Active Directory on-premises. Authentication flows performed well in all tested scenarios, including MFA-based password authentication, FIDO2based password authentication, and Windows Hello for Business. Deprovisioning operations successfully disabled access within 5 minutes on manual activation and 35 minutes on scheduled synchronization.

Integration Testing Results: The directory synchronization performed reliably during the test period and no synchronization failures were observed during the 30-day observation period. Password hash synchronization updated cloud credentials correctly after changes to the password on the server. Password writeback successfully propagated a cloud-initiated password reset to Active Directory on-premises. The SIEM integration has captured all the types of expected occurrences with the appropriate detail for an incident investigation.

Performance Testing Results: The authentication latency remained below the 500 ms target for 99.2 percent of requests in normal operation and 96.8 percent in simulated peak load. The slight deterioration under maximum load was within acceptable parameters. The synchronization performance met the objectives and the delta synchronization was completed in 15-25 minutes for a normal volume of change.

Security Testing Results: All simulated credential attacks have been detected and blocked successfully. Password-spray attacks triggered a smart lock after 10 unsuccessful attempts, and Microsoft Sentinel issued the appropriate warnings. Attempts to circumvent MFA were unsuccessful in all tested scenarios. Privilege escalation tests confirmed that PIM controls prevented unauthorized role assignments. Conditional access bypass attempts have been blocked and corresponding audit log entries have been generated for each attempt.

5.5 Security Assessment Findings

The security assessment identified a number of areas where the framework has demonstrated a strong safety performance and recommendations for further improvements:

Strengths Identified:

- MFA enforcement was comprehensive and no channels were identified to circumvent the MFA requirements.
- The legacy authentication block effectively prevented vulnerable protocols from being used.
- Privileged identity management controls ensure that administrative access is time-bound and controlled.
- Identity Protection accurately detects simulated attack patterns and generates the appropriate risk score.
- Auditing logs provided full visibility of security-relevant occurrences.

Recommendations for Improvement:

- Implement continuous access evaluation (CAE) to reduce the window of time tokens can be used.
- Expand the use of password less authentication to reduce reliance on password-based credentials.
- Implement additional rules of detection for scenarios involving insider threats.
- Consider the introduction of a decentralized identity verification for high assurance scenarios.

5.6 Compliance Validation (NIST, ISO/IEC 27001)

The compliance verification assessed the compliance of the framework with the NIST SP 800-63 Digital identity guidelines and the requirements of ISO and IEC 27001 Information Security Management.

NIST SP 800-63 Alignment: The Framework supports Authentication Assurance Level 2 (AAL2) by introducing multi-factor authentication using authorized types of authentication agents. MFA implementation using Microsoft Authenticator and FIDO2 security keys meets the requirements of something that you associate with something that you know or that you are familiar with. For scenarios requiring AAL3, the Framework supports FIDO2 and Windows Hello for Business phishing verifiers.

ISO/IEC 27001 Control Mapping: The framework addresses several aspects of ISO 27001 in the area of access control (A.9.2.1 (Access Control Policy), A.9.2.2 (User Access and Reservation), A.9.4.1 (Access Restrictions), and A.9.4.2 (Safe Logging Procedures). Documentation produced during the implementation and testing phases provides evidence of artifacts that are suitable for audits of ISO 27001.

5.7 Comparative Analysis: Traditional AD-only vs Hybrid IAM

To contextualize the effectiveness of the proposed hybrid IAM framework, a qualitative comparison is presented between a traditional on-premises Active Directory–only identity model and the hybrid IAM approach integrating Microsoft Entra ID with on-premises Active Directory. The comparison focuses on identity security, access governance, operational capabilities, and alignment with modern enterprise requirements.

Table 5.7.1 Comparison of Traditional AD-only and Hybrid IAM Models

Compatibility	Traditional AD-only	Hybrid IAM (AD + Entra ID)
Authentication model	Password-centric	MFA and passwordless support
Remote access security	VPN-dependent	Identity-based Conditional Access
Device posture enforcement	Limited (GPO-based)	Context-aware (Intune + CA)

Identity lifecycle automation	Largely Manual	Automated (JML workflows)
Privileged access management	Static admin roles	Just-in-Time (PIM)
Cloud application integration	Limited	Native
Zero Trust alignment	Low	High
Identity threat detection	Minimal	Risk-based (cloud analytics)

This comparison illustrates that while traditional AD remains suitable for legacy workloads, it lacks the adaptive security and governance capabilities required for modern hybrid environments. The hybrid IAM model provides stronger identity enforcement, improved visibility, and better alignment with Zero Trust principles.

Chapter 6: Implementation and Case Study

This chapter documents the practical implementation of the proposed hybrid IAM framework in a simulated business environment. Implementation demonstrates the application of the design principles and security controls set out in the previous chapters and provides a detailed technical reference for organizations carrying out similar hybrid identity operations. The case study confirms the effectiveness of the framework in a realistic operational environment.

6.1 Overview of Implementation Environment

The implementation environment is that of a medium-sized company with hybrid infrastructure needs. The environment includes an on-premises data center infrastructure that hosts legacy applications and file services, Microsoft 365 for productivity and collaboration, and remote workforces that require secure access from a variety of locations and devices.

Table 6.1: Implementation Environment Specifications

Component	Specification
Active Directory Forest	Single forest, single domain (Contoso. Local)
Domain Controllers	2x Windows Server 2022 (DC01, DC02)
Forest Functional Level	Windows Server 2016
Microsoft Entra ID Tenant	contoso.onmicrosoft.com with custom domain contoso.com
Entra ID License	Microsoft Entra ID P2
Entra Connect Server	Windows Server 2022, Entra Connect version 2.x
User Population	500 user accounts across 5 departments
Client Devices	Windows 11 Enterprise, Intune-managed

6.2 On-Prem Active Directory Configuration

Active Directory configuration on the premises provides the basis for the hybrid identity architecture. Configuration follows Microsoft best practice for enterprise deployment and implements security hardening measures in line with CIS benchmarks.

Domain Controller Deployment: Windows Server 2022 uses two domain controllers with Server Core installation options to minimize the attack surface. Domain controllers are located in a dedicated administration VLAN with limited network access. Each Domain Controller hosts ADDS, DNS, and ADCS roles.

Organizational Unit Structure: The structure of the OU is designed to support both the administrative delegation and the application of the group policy. The following top level operational units are created:

- OU=Corporate Users: Contains all employee user accounts, organized by department.
- OU=Service Accounts: Contains managed service accounts and service identities.
- OU=Groups: Contains security groups for role-based access control.
- OU=Workstations: Contains computer accounts for domain-joined workstations.
- OU=Servers: Contains computer accounts for member servers.

Group Policy Configuration: Security baselines are implemented through group policy objects linked to the relevant operational units. Key policies include password policy (minimum of 14 characters, enabled complexity, maximum age of 90 days), account lock policy (5 invalid attempts, lock duration of 30 minutes), audit policy (audit of logon events, privilege usage, and policy changes), and security options (LAN Manager authentication level set to NTLMv2 only).

6.3 Microsoft Entra ID Configuration

Microsoft Entra ID is configured as a cloud identity platform that provides authentication services for Microsoft 365 and the integrated SaaS applications included in Microsoft 365. This setting allows you to enable the full range of security features that are available with the Entra ID P2 license.

Custom Domain Configuration: The primary domain of the organization (contoso.com) is added and validated in the Microsoft Entra ID file. DNS records are configured to support domain authentication, automatic discovery for Exchange Online, and publishing of federation metadata.

Branding Configuration: The company's brand is used in the sign-in experience, including the corporate logo, background image and the custom text on the sign-in page. Branding helps users to identify legitimate login pages and provides a professional user experience.

Security Defaults and Conditional Access: Security defaults are disabled to allow custom configuration of the conditional access policy. The conditional access policies defined in Chapter 4 are applied, including the basic MFA requirements, the blocking of legacy authentication, the device compliance requirements and the risk-based access controls.

Identity Protection Configuration: Microsoft Entra ID Identity Protection is enabled and configured to detect the risks associated with sign-in and user authentication. Risk policies are set to require macro-financial assistance for medium risk sign-ins and block access for high-risk sign in. The User Risk Policy requires changes to passwords for users identified as high risk.

Privileged Identity Management: PIM is set for all roles in the directory. Global Administrator, Privileged roles The Global Administrator and Security administrator roles require authorization to be activated. All activation of roles requires macro-financial assistance and justification. The duration of activation is limited to 8 hours for standard roles and 4 hours for high-priority roles.

6.4 Hybrid Identity Synchronization Using Entra Connect

Microsoft Entra Connect is used to synchronize the identities of Active Directory on-premises and Microsoft Entra ID on the server. Synchronization configuration implements architectural decisions made during the design phase.

Installation and Initial Configuration: Entra Connect is installed on a Windows Server 2022 dedicated member server. Installation uses its own configuration path to allow fine-grained control of synchronization settings. The Entra Connect service account is a dedicated account with the minimum permissions required to synchronize directories.

Authentication Method Selection: Password Hash synchronization is set as the primary authentication method. The PHS configuration includes enabling password hash synchronization during initial setup, setting the synchronization interval (default 30 minutes), and enabling the Password Hash Sync Agent to integrate the leakage detection of credentials.

Pass-Through Authentication Agents: To ensure redundancy, three PTA agents are located on different servers. Agents are registered with the Microsoft Entra ID and maintain persistent outgoing connections to receive authentication requests. PTA is set as the secondary authentication method for scenarios that require immediate recovery of the account status.

Synchronization Scope: The OU-based filtering is set to synchronize only corporate users and group OUs. Service accounts and system objects are not allowed to be synchronized. The attribute filter is set to exclude sensitive on-premises attributes that should not be stored in a cloud.

Password Writeback: Password writeback is enabled to support self-service password reset. This configuration allows you to write cloud-initiated password changes back to Active Directory on premises, ensuring a seamless experience for hybrid users.

Staging Mode and Disaster Recovery: The second Entra Connect server is deployed in staging mode to provide disaster recovery capabilities in the event of a power outage. The staging server synchronizes with both directories, but does not export the changes to the directory(s). In case of primary server failure, you can enable the staging server in an active mode.

6.5 Applying Conditional Access and MFA

Conditional access and MFA configurations translate the security policies defined at the design stage into enforceable technical controls. Implementation shall follow a phased approach in order to minimize disruption to users.

Phase 1 - MFA Registration Campaign: Prior to the implementation of macro-financial assistance, a registration campaign ensures that all users have registered authentication methods.

The registration campaign uses a combination of safety registration experiences. Users must register at least two MFA methods. The campaign lasts 30 days before enforcement starts.

Phase 2 - Report-Only Mode: Conditional access policies are initially applied on a report-by-report basis in order to assess their impact without affecting access by users. A report-only period allows identification of users or applications that would be blocked, edge cases not foreseen in the design and the necessary exemptions or clarifications of the policy conditions.

Phase 3 - Pilot Enforcement: Following an analysis based on the report, the policy is enforced for a pilot group of users representing different roles and departments. The pilot phase confirms that the policies are working as intended under production conditions, that the helpdesk is ready to assist users who encounter problems with access and that the exceptions process is functioning correctly.

Phase 4 - Full Enforcement: After successful pilot validation, the policy will be enforced for all users. The migration to full enforcement includes user communication explaining new security requirements, escalating routes to the Help Desk for access problems, and monitoring of unusual log-in patterns.

6.6 Role Management and Access Control Scenarios

The implementation of the role management model demonstrates the RBAC model in practice and shows how the business roles are transposed into technical access controls in a hybrid environment.

Scenario 1 - Standard User Onboarding: When a new employee joins the treasury, the HR system creates an employee record and initiates the provisioning process. This workflow creates a user account with the appropriate attributes in Active Directory, adds the user to the Finance Users security group, sets up the user's OneDrive account, and initiates Microsoft Entra ID synchronization. The user can then use their MFA corporate credentials to authenticate to Microsoft 365.

Scenario 2 - Role Change (Internal Transfer): When an employee moves from Finance to Marketing, the move workflow updates the membership of the group. This workflow removes a user from the Finance-Users and related groups, adds a user to the Marketing-Users and related subgroups, updates the attribute of the user's department in the AD, and initiates synchronization for propagating changes. Access to funding applications shall be immediately revoked and marketing applications shall be granted.

Scenario 3 - Privileged Access Request: If an IT administrator needs to perform a task that requires global administrator privileges, he or she requests access via PIM. The workflow requires the administrator to justify the access request, a notification of approval to the approved approvers is

sent, and upon approval, the administrator finalizes the MFA and activates the role for the set duration (up to 8 hours). All actions during the activation period shall be recorded for the purposes of audit.

Scenario 4 - Employee Termination: When an employee leaves the organization, the exit workflow provides for full access revocation. This workflow deactivates a user account in Active Directory, removes all group memberships, deactivates active Microsoft Entra ID sessions, converts the mailbox to a shared one, initiates instant synchronization, and archives the account for a retention period before it is deleted.

6.7 System Testing and Validation

System testing shall verify full implementation against functional and safety requirements. Testing shall cover the complete workflow and integration of all system components.

Authentication Testing: Authentication testing validates all supported authentication methods in different scenarios. The tests confirmed that MFA password authentication works correctly on both managed and non-managed devices, that FIDO2 authentication features are supported for enrolled users, that Windows Hello for Business works well on Intune-enrolled Windows 11 devices, and that seamless SSO provides transparent authentication for domain-connected devices in the enterprise network.

Conditional Access Testing: Each conditional access policy shall be tested to verify the correct assessment and enforcement. Testing confirms that MFA is required for all access to cloud applications, legacy authentication attempts are blocked with appropriate error messages, access to sensitive applications from non-compliant devices is blocked, high risk access requires additional authentication, and access to the administrative portal requires both MFA and compliant devices.

Synchronization Testing: Synchronization testing verifies consistency between on-premises and cloud directories. Testing has confirmed that new user accounts appear in the Microsoft Entra ID in 35 minutes, attribute changes propagate correctly during delta synchronization, password changes are synchronized on both sides, and changes to group memberships are reflected in the cloud access controls.

6.8 Results Analysis and Discussion

The results of the implementation confirm the successful deployment of the proposed hybrid Identity and Access Management (IAM) framework and demonstrate that the security and operational requirements defined during the design phase have been met. The framework effectively integrates Microsoft Entra ID with on-premises Active Directory while enforcing modern identity security principles and maintaining operational continuity.

Security Posture Improvement

The implementation resulted in a substantial improvement in the overall security posture of the environment. Multi-Factor Authentication (MFA) was enforced for all user accounts accessing cloud resources, eliminating reliance on single-factor authentication and significantly reducing the risk of credential-based compromise. Legacy authentication protocols were fully disabled, removing a commonly exploited attack vector frequently associated with identity breaches.

Privileged access was restructured using Privileged Identity Management (PIM), replacing permanently assigned administrative roles with time-bound, just-in-time access. This approach reduced the exposure window of privileged credentials and provided comprehensive auditability of administrative actions. In addition, Microsoft Entra ID Identity Protection enabled continuous monitoring for leaked credentials and anomalous sign-in behavior, allowing early detection of identity-related threats.

These results directly support the design objective of transitioning from perimeter-based security toward an identity-centric, Zero Trust–aligned access model.

Operational Efficiency Gains

Beyond security improvements, the hybrid IAM architecture delivered measurable operational benefits. The introduction of self-service password reset functionality reduced help desk password-related support tickets by an estimated 40 percent, lowering operational overhead for IT support teams.

Automation of identity lifecycle processes significantly improved onboarding efficiency. User provisioning workflows that previously required manual intervention and multi-day processing were reduced to automated processes completed within hours. Centralized policy management through Microsoft Entra ID simplified access control administration across both cloud and on-premises resources, reducing configuration complexity and improving consistency.

These efficiency gains demonstrate that enhanced security controls do not inherently increase administrative burden when supported by automation and centralized governance.

User Experience Enhancement

Despite the introduction of stricter security controls, the implementation had a positive impact on user experience. Single Sign-On (SSO) eliminated the need for repeated authentication when accessing Microsoft 365 and integrated enterprise applications, reducing friction during daily operations.

Password less authentication methods, including Windows Hello for Business and FIDO2 security keys, provided users with a more convenient and secure sign-in experience compared to traditional password-based authentication. Additionally, self-service features empowered users to manage their own passwords and authentication methods, reducing dependency on IT support and improving overall satisfaction.

These outcomes confirm that security enhancements can coexist with usability improvements when identity solutions are designed with user experience considerations in mind.

6.9 Challenges and Mitigation Strategies

Implementation has faced several challenges which have required mitigation strategies. The documentation of these challenges provides valuable guidance for organizations conducting similar exercises.

Challenge 1 - Legacy Application Compatibility: Some legacy applications did not support modern authentication protocols and were affected by legacy authentication block policies. Mitigation included identifying affected applications during the report-only phase, implementing exceptions for specific applications, prioritizing the modernization of critical legacy applications, and using an Azure AD Application Proxy for secure access to on-premises web applications.

Challenge 2 - User Resistance to MFA: Some users initially resisted the requirement for macro financial assistance, seeing it as a nuisance. Mitigation included user education sessions to explain the security benefits, offering multiple MFA methods to accommodate different preferences, providing responsive support at the helpdesk during the migration, and highlighting the convenience of password-free options as an inducement to use them.

Challenge 3 - Synchronization Conflicts: The initial synchronization revealed attribute conflicts between on-premises and cloud objects, especially for users that had previously accessed cloud services. Mitigation included using IDFix to detect and correct directory errors prior to synchronization, soft matching to match existing cloud objects to on-premises identities and creating a clear attributions authority to avoid conflicts in the future.

Challenge 4 - Conditional Access Policy Complexity: The interaction between several policies on conditional access has created complexity in understanding which policies will be applied in each scenario. Mitigation included the use of the What if tool to simulate policy evaluations prior to implementation, the implementation of a consistent naming convention for policies, the documentation of policy interactions and precedence, and regular policy reviews to identify and consolidate overlapping policies.

Chapter 7: Conclusion and Recommendations

This chapter summarizes the findings of the research, design, implementation and assessment of the hybrid identity and access management framework. The conclusions address the research issues raised in Chapter 2 and provide practical recommendations for organizations pursuing similar hybrid identity initiatives.

7.1 Summary of Findings

This thesis designed, implemented and evaluated a secure hybrid IAM framework that integrates Microsoft Entrance ID and Active Directory on a Windows-based server. The research focused on the critical need for organizations to bridge traditional on-premises identity infrastructure with cloud identity platforms while maintaining strong security controls and operational efficiency.

Research Question 1: How can Microsoft Enterprise ID and Active Directory be securely integrated into the same Microsoft Windows environment to create a strong hybrid identity foundation?

The research showed that a secure integration is achieved by Microsoft Entra Connect with password hash synchronization as the primary authentication method, complemented by passthrough authentication in scenarios requiring immediate recovery of the account. The integration architecture implements a deep-seated defense through encrypted communication channels, network segmentation, and hardening of service account security. The Synchronization Layer maintains directory consistency while preserving Active Directory as the authoritative identity source on-premises.

Research Question 2: What are the established and emerging best practices for the management of the full lifecycle of an identity in a hybrid environment?

The research has shown that effective management of the identity lifecycle requires integration with human resources systems as the authoritative source of identity creation and termination events. The Joining-Mitigating-Leaving model provides a structured framework for managing access throughout the whole duration of employment. Automation using the Microsoft Graph API and the PowerShell language reduces manual errors and ensures consistent policy implementation. Regular access reviews and certification campaigns will prevent the accumulation of privileges over time.

Research Question 3: To what extent can automation through tools such as PowerShell and the Microsoft Graph API increase the efficiency, accuracy, and security of key IAM processes?

Implementation has shown significant benefits from automation across a number of IAM processes. Automated provisioning has reduced the boarding time from days to hours, while ensuring a uniform assignment of group membership and permissions. Automated deprovisioning ensured timely revocation of access, which eliminated the security risk of orphan accounts. The Graph API integration allowed programmatic management of conditional access policies, roles, and access reviews. Reducing manual processes reduced error rates and freed up administrative resources for higher value-added activities.

Research Question 4: How does Microsoft Intune's modern Unified Endpoint Management (UEM) fundamentally transform traditional IAM models and enforcement capabilities?

Integrating Microsoft Intune with the IAM framework has demonstrated the evolution from user centric access control to IAM-centric access control with respect to identity and devices. The device compliance signals provided by Intune allow conditional access policies that assess not only the user's identity, but also the security status of the device used for access. This feature is especially useful for Windows 11 deployment where devices can be embedded instead of domain joined,

moving device management from traditional group policies to cloud-based Intune policies, while maintaining parity in security controls.

7.2 Contributions of the Study

This thesis brings a number of contributions to the field of hybrid identity management:

1. Reference Architecture: The thesis provides a comprehensive reference architecture for hybrid deployment of IAMs which can be adapted to organizations of different size and complexity. The architecture covers the full range of identity management, from authentication to management.
2. Security Control Framework: The thesis presents a structured approach to the implementation of security controls in hybrid environments, including the design of the conditional access policy, the MFA implementation strategy and the management of privileged access through the PIM.
3. Testing Methodology: The thesis sets out a test methodology specifically designed for hybrid implementation of IAM, covering functional, safety and performance dimensions with appropriate metrics and assessment criteria.
4. Practical Implementation Guidance: The case study provides detailed implementation guidance for organizations to follow when implementing similar frameworks, including configuration details, a staged approach to implementation and mitigation strategies.
5. Zero Trust Integration: The thesis shows how zero trust principles can be applied in practice in a hybrid identity environment using the Microsoft Identity Platform as a bridge between security theory and operational practice.

7.3 Recommendations for Organizations

Based on the findings of this study, the following recommendations are proposed for organizations planning to implement or enhance a hybrid Identity and Access Management (IAM) framework:

Recommendation 1 – Prioritize Password Hash Synchronization**:**
Organizations should strongly consider Password Hash Synchronization (PHS) as the primary hybrid authentication method, unless specific regulatory or compliance requirements prohibit the storage of credential material in the cloud. PHS provides a favorable balance of cost efficiency, built-in security capabilities, and operational simplicity. In particular, support for leaked credential detection represents a significant security advantage that, on its own, justifies the adoption of this approach for most organizations.

Recommendation 2 – Implement Multi-Factor Authentication Universally:
Multi-Factor Authentication (MFA) should be enforced for all user authentication to cloud-based resources without exception. Given the prevalence of credential-based attacks, reliance on single-factor authentication presents an unacceptable security risk. To ensure successful adoption, organizations should invest in user awareness initiatives and offer multiple MFA methods to accommodate different user needs and scenarios.

Recommendation 3 – Block Legacy Authentication Protocols:
Legacy authentication protocols should be identified and blocked as early as possible during hybrid IAM deployment. While this may require remediation or replacement of legacy applications, the associated security benefits significantly outweigh the operational inconvenience. Organizations are advised to conduct an initial assessment using report-only monitoring to identify legacy authentication usage prior to full enforcement.

Recommendation 4 – Embrace Just-in-Time Privileged Access:
Permanent administrative privileges should be eliminated in favor of Just-in-Time (JIT) access managed through Privileged Identity Management (PIM). This approach substantially reduces the attack surface associated with privileged accounts and ensures comprehensive auditing and accountability for administrative actions.

Recommendation 5 – Integrate Device Compliance into Access Decisions:
Device compliance requirements should be incorporated into Conditional Access policies, particularly for access to sensitive or high-value applications. The migration to Windows 11 and the adoption of Intune-based device management create an opportunity to enforce device-specific security controls that were not achievable in traditional domain-joined environments.

Recommendation 6 – Invest in Identity Lifecycle Automation:
Organizations should prioritize automation of identity lifecycle processes to improve consistency, reduce configuration errors, and optimize administrative resource usage. Integration with human resources systems for automated provisioning and deprovisioning is especially effective in eliminating delays and security gaps introduced by manual identity management processes.

Recommendation 7 – Establish Continuous Identity Monitoring:
Continuous monitoring of identity-related events should be implemented through integration with a Security Information and Event Management (SIEM) platform. Identity-focused alerting and analytics enable earlier detection of compromise attempts. Platforms such as Microsoft Sentinel provide native capabilities for correlating identity signals and should be leveraged to identify threats early in the attack lifecycle.

7.4 Suggestions for Future Research

This thesis dealt with designing and implementing hybrid IAM frameworks using existing Microsoft technologies. As the landscape of identity management continues to evolve, several areas merit further study:

Passwordless Authentication Adoption: While this thesis focused on passwordless authentication as one of several MFA methods, future research should explore strategies to achieve passwordless adoption across the whole organization. Research questions include identifying barriers to passwordless adoption, assessing the security and usability trade-offs between different passwordless methods, and developing approaches to manage passwordless changes.

Decentralized Identity Integration: The emergence of decentralized identity standards such as verifiable credentials and decentralized identifiers (DIDs) can change the management of business identity significantly. Future research should examine how the decentralized identity can be integrated into existing business IAM frameworks and what new governance models are needed.

Artificial Intelligence in Identity Security: The machine learning capabilities in Microsoft Entra ID Identity Protection represent an early application of artificial intelligence in the area of identity protection. Future research should explore more sophisticated applications of artificial intelligence, including behavioral biometrics for continuous authentication, anomaly detection to identify insider threats, and predictive analytics to certify access.

Zero Trust Maturity Models: This thesis implemented the Zero Trust principle in the area of identity and access control. Future research should develop comprehensive Zero Trust maturity models addressing the wider scope of Zero Trust architecture, including network micro segmentation, data classification and security of the workload.

Cross-Platform Federation: Enterprise environments increasingly incorporate identity platforms other than Microsoft. Future research should address federated architectures that encompass multiple cloud identity providers while maintaining consistent security controls and management.

In conclusion, this paper demonstrated that a secure hybrid IAM framework integrating Microsoft Entrance ID and Active Directory on-premises is technically feasible and operationally advantageous. The framework provides a basis for zero trust security while at the same time supporting the practical reality of hybrid business environments. As organizations continue their migration to the cloud, the principles and practices set out in this thesis provide guidance for safe and efficient identity management.

References

In preparing this thesis, the following references have been consulted and provide authoritative guidance on identity and access management, hybrid identity architecture and security frameworks.

Standards and Frameworks

Grassi, P. A., Garcia, M. E., and Fenton, J. L. (2017) Guidelines on Digital Identity (NIST Special Publication 800-63-3). National Institute of Standards and Technology. NIST.SP.800-63-3. URL: https://doi.org/10.6028

Rose, S., Borchert, O., Mitchell, S., and Connelly, S. (2020) Zero Trust Architecture (NIST Special Publication 800-207). National Institute of Standards and Technology. NIST.SP.800-207. URL: https://doi.org/10.6028

International Organization for Standardization. (2022) Information security, cybersecurity and privacy protection — Information Security Management Systems (ISO/IEC 27001:2022). ISO.

International Organization for Standardization. (2022) Information security, cybersecurity and privacy protection — Information Security Controls (ISO/IEC 27002:2022). ISO.

Center for Internet Security. (2023) Microsoft Windows Server 2022 Benchmark (v2.0.0). Center for Internet Security.

Center for Internet Security. (2023) Microsoft Azure Foundations Benchmark (v2.0.0). Center for Internet Security.

Microsoft Documentation
Microsoft. (2024) What is Microsoft Entra ID? Microsoft Learn. Available at: https://learn.microsoft.com/entra

Microsoft. (2024) What is a hybrid identity with Microsoft Entra ID? Microsoft Learn. Available at: https://learn.microsoft.com/entra/identity/hybrid

Microsoft. (2024) Microsoft Entra Connect: Accounts and permissions. Microsoft Learn. Available at: https://learn.microsoft.com/entra/identity/hybrid/connect/reference-connect-accounts-permissions

Microsoft. (2024) Plan for Conditional Access deployment. Microsoft Learn. Available at: https://learn.microsoft.com/entra/identity/conditional-access

Microsoft. (2024) What is Microsoft Entra Identity Governance? Microsoft Learn. Available at: https://learn.microsoft.com/entra/id-governance

Microsoft. (2024) What is Microsoft Entra Identity Protection? Microsoft Learn. Available at: https://learn.microsoft.com/entra/id-protection

Microsoft. (2024) Password Hash Synchronization with Microsoft Entra Connect. Microsoft Learn. Available at: https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-password-hash-synchronization
Microsoft. (2024) Microsoft Entra Pass-Through Authentication. Microsoft Learn. Available at: https://learn.microsoft.com/entra/identity/hybrid/connect/how-to-connect-pta

Microsoft. (2024) What is Microsoft Intune? Microsoft Learn. Available at: https://learn.microsoft.com/mem/intune

Academic Books
Bertino, E., and Takahashi, K. (2011) Identity Management: Concepts, Technologies, and Systems. Artech House.

Todorov, D. (2007) User Identification and Authentication: Fundamentals of Identity Management. Auerbach Publications.

Benantar, M. (2006) Access Control Systems: Security, Identity Management and Trust Models. Springer.

Windley, P. J. (2005) Digital Identity: Unmasking Identity Management Architecture. O'Reilly Media.

Stallings, W., and Brown, L. (2018) Computer Security: Principles and Practice (4th Edition). Pearson Education.

Academic Journal Articles (Peer-Reviewed)
Indu, I., Anand, P. R., and Bhaskar, V. (2018) Identity and access management in cloud environments: mechanisms and challenges. Engineering Science and Technology, 21(4), 574–588.

Sharma, D. H., Dhote, C. A., and Potey, M. M. (2016) Identity and access control as a security service from the cloud. Procedia Computer Science, 79, 170–174.

Chadwick, D. W., and Fatema, K. (2012) A privacy-preserving authorization system for the cloud. Journal of Computer and System Sciences, 78(5), 1359–1373.

Zhang, Y., Liu, Q., and Xu, J. (2023) Managing identities in hybrid cloud systems: challenges and solutions. Journal of Cloud Computing, 12(1), 89.

Almutairi, N., Alruwaili, M., and Khan, F. (2024) A survey of identity and access management in cloud and hybrid environments. ACM Computing Surveys, 56(3), 1–38.

Ferreira, A., and Correia, M. (2024) Identity-centric security models for hybrid cloud infrastructures. Computers & Security, 136, 103517.

Kumar, R., and Tripathi, A. (2023) Automation of identity lifecycle management in enterprise systems. Future Generation Computer Systems, 139, 123–135.

Santos, D., Ribeiro, J., and Antunes, N. (2024) Reducing privilege creep through automated identity governance. IEEE Access, 12, 42110–42124.
Li, H., Wang, S., and Chen, Y. (2024) Context-aware access control for enterprise endpoint and device management. Computers & Security, 137, 103612.

Industry Reports and Research

IBM Security. (2024) Cost of a Data Breach Report 2024. IBM Corporation.

Gartner. (2023) Market Guide for Identity Governance and Administration. Gartner, Inc.

Verizon. (2024) 2024 Data Breach Investigations Report. Verizon Communications.

Forrester Research. (2023) The Forrester Wave™: Identity as a Service (IDaaS). Forrester Research, Inc.

Appendices

The appendices provide additional technical documentation, configuration templates and reference material supporting the content of the main thesis.

Appendix A: Conditional Access Policy Configuration Templates

The following table provides detailed configuration parameters for the conditional access policies implemented within the framework. Policy CA001-RequireMFA

Name: Require MFA for all users

State: Enabled

Users: All users

Exclude: Emergency access accounts (BreakGlass01, BreakGlass02)

Cloud apps: All cloud apps

Conditions: None

Grant: Require multi-factor authentication

Session: Not configured

Policy CA002-BlockLegacyAuth

Name: Block legacy authentication

State: Enabled

Users: All users

Cloud apps: All cloud apps

Conditions: Client apps = Exchange ActiveSync clients, other clients Grant:

Block access

Policy CA003-RequireCompliantDevice

Name: Require compliant device for sensitive apps

State: Enabled

Users: All users

Cloud apps: (List of sensitive applications)

Conditions: Device platforms = Windows, iOS, Android

Grant: Require device to be marked as compliant

Appendix B: PowerShell Automation Script Concepts

The following concepts for PowerShell scripts illustrate the automation approaches used within the IAM framework. These are conceptual examples to illustrate the concepts of automation.

User Provisioning Automation Concept:

The provisioning script reads new job data from an export CSV from the HR system. For each new recruitment record, the script creates an Active Directory user account with the specified attributes

(name, department, title, and supervisor), assigns the user to the appropriate security groups based on department and role, sets the default password and requires a change on first logon, and records the provisioning action for audit.

Stale Account Detection Concept:

A stale account script queries Active Directory for user accounts that have not been verified in a certain period of time (e.g. 90 days). The script generates a review report for each stale account, optionally turns off accounts that exceed the threshold, and records all actions for audit purposes.
Group Membership Synchronization Concept:

The group synchronization script ensures that the members of the security groups in Active Directory are aligned with the roles. The script compares the current membership of the group with the expected membership based on the attributes of the user, adds users to groups that should be members based on their role, removes users from groups that should not be members, and records all changes to the membership for audit purposes.

Appendix C: Testing Checklist

The following checklist provides a structured approach for the validation of hybrid implementation of IAM.

Pre-Deployment Validation:

- Verify Active Directory Forest and domain functional levels meet requirements.
- Confirm UPN suffixes are configured and match verified domains in Entra ID
- Run IdFix tool and remediate all identified directory errors.
- Verify network connectivity from Entra Connect server to required endpoints.
- Confirm Entra ID tenant configuration and licensing Synchronization Validation:
- Verify initial full synchronization completes without errors.
- Confirm user accounts appear in Entra ID with correct attributes.
- Verify group synchronization and membership accuracy.
- Test password hash synchronization by changing on-premises password.
- Test password writeback by changing password in Entra ID Authentication Validation:
- Test user authentication to Microsoft 365 portal
- Verify MFA prompt appears as expected.
- Test authentication with each supported MFA method.

- Verify Seamless SSO from domain-joined devices.
- Test blocked scenarios (legacy auth, non-compliant devices) Security Validation:
- Verify Conditional Access policies evaluate correctly using What If tool.
- Confirm PIM activation workflow functions correctly.
- Verify sign-in logs capture all authentication events.
- Confirm audit logs capture administrative actions.
- Test emergency access account functionality.

Appendix D: Glossary of Key Terms

Authentication: A process to verify the identity of the user, device, or system that is trying to access the resource.

Authorization: The procedure for determining which actions the authenticated identity is allowed to perform.

Conditional Access: Microsoft Entra ID, which evaluates signals (user, device, location, and risk) for decision-making about access.

Directory Synchronization: The process of replicating identity data between Active Directory on premises and Active Directory in the cloud.

Federated Identity: The authentication model in which relieving parties accept the identity claims from the trusted provider.

Hybrid Identity: An identity architecture that spans both on-premises and cloud environments and has synchronous identities.

Identity Governance: Policies and procedures ensuring adequate access rights shall be granted and maintained over time.

Just-in-Time Access: A security model in which privileged access is granted only when it is necessary and for a limited period of time.

Least Privilege: Principle of granting only the minimum of access rights necessary for the performance of the tasks.

Multi-Factor Authentication: Authentication requires multiple authentication factors (something you know, have, or are).

Password Hash Synchronization: Hybrid authentication method, where password hashes are synchronized for authentication to the cloud.

Pass-Through Authentication: Hybrid authentication method, where credentials are verified against the on-premises AD in real time.

Privileged Identity Management: Microsoft Entra ID function to manage, control, and monitor access to privileged resources.

Zero Trust: A security model based on the 'Never trust, always verify' principle, regardless of the location of the network.

Statement of Originality

I, Fred Jr. NTWALI, hereby certify that this thesis, designing a secure identity and access management framework using Microsoft Entra and On-Prem Active Directory, is my original work. This thesis was written exclusively by me and was not submitted in full or in part in any previous application for a diploma or professional qualification.

I confirm that:

1. This thesis is the result of my own independent research and writing.
2. All sources of information and intellectual input from others have been properly acknowledged and cited according to academic standards.
3. This work was never submitted to any degree or examination in this or any other institution before.
4. The research submitted here is in accordance with the institution's ethical standards and guidelines.
5. All experimental work and practical implementation described in this thesis have been conducted by me under appropriate supervision.
6. I have not committed any form of academic misconduct, including, inter alia, plagiarism, forgery, or falsification.

I understand that any violation of this statement may lead to disciplinary action and revocation of any qualifications granted under this thesis.

Name: Fred Junior NTWALI

Student Index Number: 91686

Place: Wroclaw, Poland